

Komuta-Kontrol (C2) Trafiğinin Evrimi ve NDR Kör Noktaları

Yönetici Makalesi & Kapsamlı Teknik Rapor

Doküman Kimliği	SOC-NDR-MASTER-001
Hazırlayan	Oğulcan (ByGhost) Erarlan
Ünvan	Senior Solutions Architect Cyber Security Specialist
Kuruluş	ByGhost Security
Web	https://byghost.tr/
GitHub	https://github.com/ByGh00st
İletişim	linkedin.com/in/byghost-tr
Kapsam	C2 Yönetici Makalesi + 12 Bölümlü Detaylı Teknik Rapor
Hedef Kitle	SOC Yönetimi, Mavi Takım Liderleri, Güvenlik Mimarları
Yöntem	Stokastik zamanlama analitiği, NDR mimarisi, uç nokta telemetri korelasyonu
Tarih	04.10.2026
Uzunluk	14.016 kelime

© 2026 Oğulcan (ByGhost) Erarlan. Bu teknik rapor Creative Commons Attribution-NonCommercial-NoDerivatives 4.0 (CC BY-NC-ND 4.0) uluslararası lisansı ile korunmaktadır. Yazılı izin ve ticari lisans anlaşması olmaksızın ticari siber güvenlik ürünlerine (EDR/NDR/XDR) doğrudan veya dolaylı entegrasyonu, türetilmesi ve kaynak gösterilmeksizin kullanımı kesinlikle yasaktır. Tam yasal bildirim ve fikri mülkiyet şartları için bkz. Ek E.

İ indekiler

B L M I: GİRİŐ VE Y NETİCİ MAKALEŐİ

1. Jitter Yanılsaması: Neden %20 Rastgele Gecikme Tek Baőına Bir Savunma Deęil
2. Evrim:  z-Benzer Trafik ve Akıő D zeyi Ayrımın   k ő 
3. Paradigma Kayması: Baęlamsal ve Nedensel Tespit

B L M II: KAPSAMLI TEKNİK RAPOR

Y netici  zeti

1. Kapsam, Varsayımlar ve Tehdit Modeli
2. Zamanlama Analizinin Matematiksel Temeli
3. Kurumsal Trafikinin İstatistiksel Parmaęı:  z-Benzerlik ve LRD
4. Kapsam Sınırı ve Operasyonel Olmayan Model Baęlamı
5. Tespit Tavanının Kapsamı
6. Taktik Kataloęu (T1 – T20)
7. Tespit M hendislięi  ıktıları (Sigma, KQL, eBPF)
8. Yanlıő Pozitif Y netimi ve  l  m
9. Olgunluk Modeli ve Yol Haritası
10. Savunma Borcu ve S rekli Kalibrasyon
11. Sonu 
12. Ekler (Matematiksel T retmeler, S zl k, ATT&CK, Kaynak a)

BÖLÜM I: GİRİŞ VE YÖNETİCİ MAKALESİ

Komuta-Kontrol Trafiğinin Evrimi: Şekillendirilmiş Zamanlama ve NDR'nin Kör Noktaları

1. Jitter Yanılsaması: Neden %20 Rastgele Gecikme Tek Başına Bir Savunma Değil

Yaygın bir varsayım, beacon aralıklarına %20 mertebesinde rastgele gecikme eklemenin ağ tespit sistemlerini atlattığı yönündedir. Bu varsayım, zamanlama analizinde iki farklı stokastik modelin karıştırılmasına dayanır ve tespit mimarisi açısından yanıltıcıdır.

İki farklı jitter modeli. İlk modelde gürültü olay zamanlarına eklenir ($t_n = nT + \epsilon_n$): ardışık aralıklar ortak gürültü terimi taşıdığı için IAT dizisi bağımlılık gösterebilir. Bu bağımlılık, (i) gürültünün iid, (ii) sonlu varyanslı olması ve (iii) olay indekslerinin fiziksel zaman sırasını koruması koşulları altında değişmez (invariant) bir biçim alabilir; lag-1 otokorelasyonun -0.5 düzeyine ulaşması bu koşullar altında geçerli bir sonuçtur. Olay sıralamasının bozulduğu veya yeniden sıralama gerektiği durumlarda, gözlenen IAT dizisinin aynı bağımlılık yapısını koruyacağı garanti edilmez. İkinci modelde gürültü aralığın kendisine eklenir ($IAT_n = T + U_n$): aralıklar bağımsızdır ve olay zamanları kümülatif olarak bir yenilenme (renewal) süreci üretir. Bu iki modelin IAT dağılımları, bağımlılık yapıları ve spektral sonuçları farklıdır; tespit mantığı kurulurken hangi modelin varsayıldığı açık olmalıdır.

Spektrum hangi nesneye aittir? Sabit bir IAT dizisinin ayrık Fourier dönüşümü yalnızca DC bileşeni üretir; ayrık spektral çizgiler, periyodik olay treninin spektrumundan kaynaklanır. Yalnızca IAT dizisine spektral analiz uygulayan bir dedektör, sabit periyotlu bir beacon'ı yapısal olarak kaçırabilir. Jitter'ın çizgi yapısına etkisi modele bağlıdır: olay-zamanı jitter modelinde çizgi genlikleri jitter dağılımının karakteristik fonksiyonuyla ölçeklenir ve bu zarfın sıfırlarına denk gelen harmonikler zayıflayabilir ya da sıfırlanabilir; aralık-jitter modelinde ise sürekli bir aralık dağılımı altında $f \neq 0$ için ayrık çizgi bileşeni bulunmayabilir. Üniform jitter örneğinde olay-zamanı modelinin zarfı $\text{sinc}(2\pi T f)$ biçimindedir ($\text{sinc}(x) \equiv \sin(x)/x$); bu ifade genel karakteristik-fonksiyon teorisinin bir örneğidir ve gerçek sistem parametrelerine ilişkin bir sonuç içermez. Gözlem süresi ve olay sayısı arttıkça spektral kestirimin istatistiksel gücü artabilir; büyüklük olay sayısına ve pencereleme yöntemine bağlıdır.

Sınırlı destek gözlemi de bağlama duyarlıdır: meşru trafik, uygulama ve protokol sınıfına bağlı olarak çok daha geniş ve iş yüküne özgü IAT destekleri gösterebilir; alt sınırlar protokol, tamponlama, zamanlayıcı ve zaman damgası çözünürlüğüne bağlı olabilir. Bu nedenle destek sınırı tek başına kanıt değil, aday bir özelliktir. Benzer biçimde, zamanlama, spektral ve dağılımsal özetler makine öğrenmesi tabanlı anomalilik modellerine girdi olarak kullanılabilir; bu modellerin performansı kullanılan temsile, eğitim verisine ve baseline'a bağlıdır. Belirli bir mimarinin başarılı olacağı, deneysel kanıt olmadan iddia edilmemelidir.

Sonuç: Olay-zamanı jitter modelinde periyodik olay treninin çizgi yapısı zayıflayabilir ancak bütünüyle ortadan kalkması zorunlu değildir; aralık-jitter modelinde ise sürekli aralık dağılımı altında $f \neq 0$ için ayrık çizgi bileşeni bulunmayabilir. Bu nedenle jitter'ın etkisi kullanılan stokastik modele bağlıdır. Jitter'a ilişkin savunma mantığı, model varsayımı açıkça belirtilerek kurulmalıdır.

2. Evrim: Öz-Benzer Trafik ve Akış Düzeyi Ayırımın Çöküşü

Birçok toplulaştırılmış Ethernet/WAN ve kurumsal trafik izinde öz-benzerlik ve uzun menzilli bağımlılık (Long-Range Dependence, LRD) gözlenmiştir; bu izlerde Hurst üsteli $H > 0.5$ rejiminde ölçülür. Toplulaştırma altında Poisson benzeri süreçler beyaz gürültüye düzleşirken, LRD sergileyen seriler bellek etkisini daha yavaş yitirir. Bu davranışın tek bir açıklaması yoktur: ağır kuyruklu kaynak davranışı güçlü bir mekanizma olmakla birlikte, çoklu ölçekli çoklama, uygulama düzeyi istek kümelenmesi ve ölçüm artefaktları da katkı verebilir.

Zamanlama profili baseline'a uyarlanmış trafik karşısında, bu makalede değeriendirilen akış düzeyi özellik ailesinde — marjinal dağılım, spektral yoğunluk, otokorelasyon, ölçekleme üsteli ve günlük ritim — sınıflar arası ayırım belirgin biçimde azalabilir. Bu, bilgi-teorik bir yokluk iddiası değildir: yüksek mertebeden bağımlılık, multifraktal yapı, protokol tutarlılığı, akışlar arası korelasyon ve uç nokta bağlamı ayırım gücünü koruyabilir. Ayırımın azalması, tespitin imkânsızlaştığı anlamına değil; tespit çabasının farklı özellik ailelerine taşınması gerektiği anlamına gelir.

3. Paradigma Kayması: Bağlamsal ve Nedensel Tespit

İnsan etkileşimli iş yükleri ile otomatik süreçler farklı bağlamsal ve zamansal değişkenlik örüntüleri gösterebilir; ancak bu ayırım mutlak değildir ve iş yüküne özgü baseline gerektirir. Değeriendirilen özellik ailesinde ayırım azaldığında, savunma değeri aşağıdaki aday özellikler üzerinde yoğunlaşabilir:

- **Ölçekleme kararlılığı:** Kayan pencerelerde ölçekleme ve kuyruk indeksi kestirimlerinin varyansı, segment baseline'ına göre değeriendirilebilir; anormal kararlılık aday bir sinyaldir ve korelasyon gerektirir.
- **Kuyruk yapısı:** Gözlenen üst-kuyruk biçiminin segment baseline'ından sistematik olarak sapması, tail-index kestirimleri ve CCDF tanılamasında aday anomali oluşturabilir.
- **Zamanlayıcı kuantizasyonu:** İşletim sistemi, çalışma zamanı, zamanlayıcı, güç politikası ve zaman damgası kaynağına bağlı kuantizasyon kümelenmeleri; host, derleme ve segment baseline'ına göre değeriendirilen aday özelliklerdir. Bu tür kümelenmeler tek başına ayırt edici değildir.
- **Filo-geneli benzerlik:** Host'lar arasında olağandışı derecede benzer zamanlama veya ölçekleme özellikleri, filo-geneli korelasyon için aday sinyal olabilir.
- **Uç nokta bağlamı:** Akış ile sürecin ilişkilendirilmesi (flow ↔ process correlation), oturum bağlamı, etkileşimli/etkileşimsiz çalışma ayırımı, ebeveyn süreç ve servis/görev bağlamı ile kullanıcı girdisi ve pencere odağı gibi bağlamsal telemetri; Windows'ta ETW, Linux'ta eBPF gibi savunma telemetrisi kaynaklarıyla toplanabilir. Terminal yokluğu, girdi olayı eksikliği veya etkileşimsiz oturum gibi sinyaller tek başına kanıt değildir; yalnızca korelasyon özellikleri olarak değeriendirilmelidir.
- **Süreç davranışı:** Süreç zamanlamasında gözlenen tekrarlı veya kuantize davranış örüntüleri, iş yüküne özgü baseline'a göre aday korelasyon özelliği olabilir.

Hiçbir sinyal tek başına kesin kanıt oluşturmaz; karar, birden çok bağımsız düzlemin korelasyonu ile verilir. Bu yaklaşımın gerektirdiği doğrulama, iş yüküne özgü baseline ve kontrollü simülasyon ile yapılmalıdır.

Operasyonel sonuç: Akış düzeyi istatistiklerin ayırt edici gücü azaldığında tespit çabası nedensellik katmanına kayabilir: "bu trafik insan benzeri mi" sorusu yerini "bu trafiği üreten süreç ve oturum bağlamı, iddia edilen kullanıcıyla tutarlı mı" sorusuna bırakır.

Public-release kapsam notu: Bu çalışma belirli bir C2 implementasyonunun mimarisini veya operasyonel üretim ayrıntılarını açıklamaz. Tüm örnekler savunma, ölçüm ve detection-engineering kavramlarını göstermek amacıyla genelleştirilmiştir.

BÖLÜM II: KAPSAMLI TEKNİK RAPOR

Yönetici Özeti

Bu rapor, komuta-kontrol (C2) trafiğinin istatistiksel analizinde savunma tarafının kullanabileceği ölçüm ve korelasyon yöntemlerini değerlendirmektedir. Kapsam yalnızca tespittir: rapor, saldırgan tarafındaki trafik üretim yöntemlerini, parametre kestirim yordamlarını ve kaçınma reçetelerini içermez (kapsam sınırı için bkz. Bölüm 4). Değerlendirme, iki yapısal soruya odaklanır:

1. Zamanlama tabanlı ayırım (jitter, periyodiklik, spektral imza) hangi koşullarda çalışır ve hangi koşullarda çöker?
2. Ayırım çıktığında hangi ölçüm katmanları savunma değeri üretmeye devam eder?

Temel Bulgular

- Jitter tek bir stokastik modeli ifade etmez; en az iki farklı modeli kapsar ve bu iki model farklı IAT dağılımları ile farklı spektral sonuçlar üretir (Bölüm 2.2). Model karıştırıldığında hem teorik gerekçe hem de dedektör eşiği hatalı kurulur. Bu rapor, olay-zamanı jitter'ı ile aralık jitter'ını ayrı ayrı ele alır.
- Uniform jitter varsayımında** olay-zamanı jitter'ı ($t_n = nT + \epsilon_n, \epsilon_n \sim U(-pT, pT)$) için IAT serisi $T + \epsilon_n - \epsilon_{n-1}$ biçimindedir ve dağılımı simetrik üçgenseldir (destek $[T - 2pT, T + 2pT]$); aralık jitter'ında ($IAT_n = T + U_n, U_n \sim U(-pT, pT)$) IAT dizisi bağımsızdır ve $[T - pT, T + pT]$ üzerinde üniformdur. Bağımlılık yapıları farklıdır: olay-zamanı jitter'ında ortak ϵ terimi nedeniyle lag-1 otokorelasyon -0.5 'tir; aralık jitter'ında aralıklar bağımsızdır. Olay zamanlarının üretim mekanizmaları farklıdır: Model A'da $t_n = nT + \epsilon_n$ doğrudan tanımlanır; Model B'de $t_n = \sum_{i \leq n} IAT_i$ kümülatif olarak oluşturulur.
- Spektral çizgiler periyodik olay treninden kaynaklanır; sabit IAT dizisinin ayrık Fourier dönüşümü yalnızca DC bileşeni üretir. Yalnızca IAT dizisine spektral analiz uygulayan dedektörler sabit periyotlu beacon'ı yapısal olarak kaçırmaz.
- Üstel jitter, bellek yoksunluğunu $X = T + Y$ değişkeninin kendisine değil, fazlalık değişkeni Y'ye taşır; doğru ifade $s \geq T$ için $P(X > s+T \mid X > s) = e^{(-\lambda T)}$ biçimindedir (Bölüm 2.3).
- Birçok toplulaştırılmış Ethernet/WAN ve kurumsal trafik izinde öz-benzerlik ve uzun menzilli bağımlılık (Long-Range Dependence, LRD) gözlenmiştir; bu izlerde Hurst üsteli uzun menzilli bağımlılık rejiminde ($H > 0.5$) ölçülür. Poisson süreçleri bu istatistiği üretemez; toplulaştırma altında beyaz gürültüye düzleşirler. Bu, tüm kurumsal trafik için evrensel bir özellik değil, ölçülmüş bir ampirik bulgudur. Bulgu, varyans ve standart sapma tabanlı eşiklerin neden kararsız olabileceğini ve neden kuyruk/log-log ölçümlerinin tercih edilmesi gerektiğini açıklar (Bölüm 3).
- Akış düzeyi ayırımın çöküşü **bilgi-teorik bir yokluk iddiası değildir**. İddia, bu raporda değerlendirilen özellik ailesiyle sınırlıdır: marjinal dağılım, güç spektral yoğunluğu, otokorelasyon, Hurst üsteli ve diyurnal profil. Yüksek mertebeden bağımlılık, multifraktal spektrum, akışlar arası korelasyon ve uygulama/protokol tutarlılığı bu ailenin dışındadır ve ayırım gücünü koruyabilir (Bölüm 5).
- Savunma tarafındaki en dayanıklı ölçüm katmanı, ağ istatistiği ile süreç/oturum bağlamının birleştirilmesidir. Ancak bu katman da koşulludur: oturum bağlamı uyumsuzluğu, servis ve etkileşimsiz (non-interactive) dağıtım modellerinde yüksek değerli bir korelasyon sinyalıdır; kullanıcı oturumu içinde çalışan süreçlerde bu sinyal bulunmayabilir (Bölüm 6.7–6.9).
- Yirmi taktik, tek başına kanıt değeri taşımayan aday özellikler ile korelasyon gerektiren sinyaller olarak ayrıştırılmıştır. Her taktik; veri kaynağı, hipotez, gerekçe, karıştırıcı faktörler, yanlış pozitif kaynakları, baseline gereksinimi, validasyon yöntemi ve kanıt gücü başlıklarıyla tanımlanmıştır (Bölüm 6).

Önerilen Aksiyonlar

#	Aksiyon	Sorumlu	Zaman Ufku
1	Kayan pencere ölçekleme ve kuyruk ölçümlerinin akış telemetrisine eklenmesi	Tespit Mühendisliği	0–30 gün

#	Aksiyon	Sorumlu	Zaman Ufku
2	Süreç/oturma bağlamının PID ve süreç başlangıç zamanı ile akışa bağlanması	Uç Nokta Güvenliği	30–60 gün
3	Zamanlayıcı kuantizasyonu aday özelliğinin segment baseline'ı ile devreye alınması	Ağ Güvenliği	30–60 gün
4	Kurum kontrollü savunma profili simülatörü ile dedektör validasyonu	Kırmızı/Mavi Takım	60–90 gün
5	İş yükü segmentasyonu ve baseline yenileme takvimi	SOC Mimarisi	60–120 gün
6	Olgunluk modelinin çeyreklik gözden geçirmeye bağlanması	Güvenlik Yönetimi	90–365 gün

Yönetim Açısından Sonuç

Kurumsal ölçekte C2 tespiti, ağ merkezli bir sınıflandırma probleminden; akış, uç nokta ve kimlik telemetrisinin nedensellik zinciri içinde birleştirildiği bir doğrulama problemine dönüşmüştür. Yatırımın, akış düzeyi eşik ayarından çapraz katman korelasyona ve ölçüm sürekliliğine kaydırılması önerilmektedir.

1. Kapsam, Varsayımlar ve Tehdit Modeli

1.1 Kapsam

Bu rapor, kurumsal ağlarda (5.000–100.000 uç nokta ölçeği) operasyon yürüten bir SOC yapısını hedef almaktadır. Kapsam dahilindeki konular:

- Zamanlama tabanlı tespit ölçümlerinin istatistiksel temeli ve sınırları.
- Ağ Tespit ve Karşılık (NDR) mimarilerinin akış düzeyi özellik uzayındaki kör noktalar.
- Akış telemetrisi ile uç nokta telemetrisinin birleştirilmesine dayalı tehdit avcılığı taktikleri.
- Tespit mühendisliği çıktıları: telemetri gereksinim matrisi, kural örnekleri, ölçüm ve olgunluk modeli.

Kapsam dışı bırakılan konular: uç nokta tabanlı bellek bozulması tespiti, kimlik bilgisi hırsızlığına yönelik savunma, e-posta tabanlı ilk erişim vektörleri, saldırgan tarafındaki trafik üretim yöntemleri (bkz. Bölüm 4).

1.2 Varsayımlar ve Kısıtlar

- **Veri sürekliliği:** Akış telemetrisi (NetFlow v9/IPFIX veya bağlantı kayıtları) en az 90 gün çevrimiçi, 12 ay arşiv olarak saklanmaktadır. Bu süreler operasyonel başlangıç noktalarıdır; gerekli pencere uzunluğu örnekleme oranına, iş yükünün durağanlığına, kestiricinin yanlılık/varyans davranışına ve mevsimsel yapıya bağlıdır (Bölüm 8.4).
- **Zaman çözünürlüğü:** Bağlantı düzeyi kayıtlar alt-milisaneye zamanlama analizi için yetersizdir; bu kayıtlar bağlantı başlangıç/bitiş damgaları ve hacim bilgisi taşır, paket düzeyi zaman serisi sağlamaz. Alt-milisaneye ölçümler yalnızca paket düzeyi yakalama altyapısı bulunan segmentlerde uygulanır.
- **Şifreleme (kurum varsayımı):** Bu raporun hedef aldığı tipik kurumsal ortamda trafiğin büyük bölümünün TLS ile şifrelendiği varsayılır. Şifreli oran ve sürüm dağılımı kuruma göre değişir; ölçülmesi ve baseline dokümantasyonunda belirtilmesi gerekir. Analiz, içerik denetimine değil; zamanlama, hacim, yön ve süreç bağlamına dayanır.
- **Kaynak kapasitesi (tasarım hedefi):** Önerilen analitik yükler için mimari hedef, mevcut SIEM/veri gölü altyapısında günlük akış hacminin %5'inden azının işlenmesidir. Bu bir **kapasite bütçesi hedefidir**; ölçülmüş bir performans sonucu değildir. Gerçek kaynak tüketimi seçilen pencere uzunluğuna, örnekleme oranına ve altyapı ölçeklendirmesine bağlıdır ve hedef ortamda ölçülmelidir.

- **Kanıt standardı:** Raporda "aday özellik" (heuristic/candidate) ile "değişmez özellik" (invariant) ayrımı korunur. Değişmez etiketi yalnızca matematiksel olarak zorunlu sonuçlar için kullanılır; gözleme dayalı göstergeler aday özellik olarak işaretlenir.

1.3 Tehdit Modeli ve MITRE ATT&CK Eşlemesi

Tehdit modeli, uzun süreli kalıcılık (long-dwell) hedefleyen ve tespit edilmemeyi hız veya hacim yerine trafik profili sadakati üzerinden optimize eden aktörleri varsayar. Bu, bir varsayımdır; raporun taktikleri bu varsayımın doğruluğuna bağımlı değildir, çünkü ölçümler gözlemlenebilir çıktılar üzerinden tanımlanır.

Aşağıdaki tabloda eşlemeler **bağlama duyarlı** olarak sunulmuştur: gözlemlenen davranış, ilgili teknikle uyumlu olabilir; bu, tek başına teknik ataması yapıldığı anlamına gelmez. Savunma analitiğinin kendisine ATT&CK tekniği atanmaz; ATT&CK saldırgan davranışını sınıflandırır.

Gözlemlenen Davranış	Uyumlu Olabileceği Teknik	Not
Uygulama katmanı protokolü üzerinden düzenli dış iletişim	T1071	Protokol seçimi tek başına ayırt edici değildir
Şifreli kanal kullanımı	T1573.002	Kurumsal trafikte yaygın; bağlam gerektirir
Çözümleme altyapısının dinamik değişimi	T1568	DNS verisi ile doğrulanmalıdır
Zamanlama penceresine bağlı transfer	T1029	Diyurnal profil ile birlikte değerlendirilir
Protokol taklidi	T1001.003	JA4/JA3 ve kayıt boyu profili ile desteklenmelidir
Zamanlayıcı güdümlü gönderim deseni	T1497.003	Zaman temelli kaçınma ile uyumlu olabilir; karıştırıcı faktörler fazladır (Bölüm 6.4)

2. Zamanlama Analizinin Matematiksel Temeli

2.1 Tespitin Nesnesi: Olay Treni ve IAT Dizisi

Zamanlama analizinde iki farklı nesne karıştırılmamalıdır. Birincisi, olay zamanlarının oluşturduğu nokta süreci (olay treni); ikincisi, ardışık olaylar arasındaki sürelerin dizisi (IAT).

Olay treni : $x(t) = \sum_n \delta(t - t_n)$
 Sabit periyot : $t_n = nT \Rightarrow X(f) = (1/T) \cdot \sum_k \delta(f - k/T)$
 IAT dizisi : $IAT_n = t_n - t_{(n-1)} = T \Rightarrow \text{DFT: yalnızca DC bileşeni}$

Spektrumdaki $1/T$ aralıklı çizgiler, periyodik olay zamanlarından kaynaklanır (Poisson toplama formülü). Sabit IAT dizisinin ayrık Fourier dönüşümü ise tek bir DC bileşeni verir: $X[0] = NT$, diğer tüm binler sıfırdır. Sonuç:

- "IAT serisinin FFT'sinde k/T harmonikleri" ifadesi hatalıdır.
- Doğru tespit uzayı, olay zamanlarının periodogramı (veya eşdeğer biçimde olay treni otokorelasyonu) ya da Lomb-Scargle periodogramıdır.
- Operasyonel sonuç: yalnızca IAT dizisine spektral analiz uygulayan dedektörler, sabit periyotlu beacon'ı yapısal olarak kaçırır. Bu, saha araştırmalarında karşılaşılan bir uygulama hatasıdır.

2.2 İki Farklı Jitter Modeli

"Jitter" tek bir stokastik modeli ifade etmez. Aşağıdaki iki model farklı IAT dağılımları, farklı bağımlılık yapıları ve farklı spektral sonuçlar üretir; tespit gerekçesi kurulurken hangi modelin varsayıldığı açık olmalıdır.

Model A — Olay-zamanı (event-time) jitter. Jitter, olay zamanlarına eklenir:

$t_n = nT + \epsilon_n$, ϵ_n iid, $E[\epsilon] = 0$, $\text{Var}(\epsilon) = \sigma_\epsilon^2$
 $IAT_n = t_n - t_{(n-1)} = T + \epsilon_n - \epsilon_{(n-1)}$

Sonuçlar:

- $\epsilon \sim U(-pT, pT)$ olduğunda $IAT_n = T + \epsilon_n - \epsilon_{(n-1)}$ **simetrik üçgensel** dağılıma sahiptir; desteği $[T - 2pT, T + 2pT]$ aralığıdır. Üçgensellik bu dağılım tercihinin özgüdür: genel iid ve sonlu varyanslı ϵ için IAT dağılımının üçgensel olması gerekmez. Genel durumda garanti edilen iki sonuç ayrıca belirtilmelidir: (i) IAT_n dağılımı T etrafında **simetrik** (iid ϵ için $\epsilon_n - \epsilon_{(n-1)}$ ile $\epsilon_{(n-1)} - \epsilon_n$ aynı dağılıma sahiptir), (ii) $Var(IAT) = 2\sigma_\epsilon^2$ ve $\rho_1 = -0.5$ dağılım biçiminden bağımsız olarak korunur.
- **Geçerlilik koşulu ($p < 0.5$)**: Fiziksel olay sıralamasının korunması, yani indekslenen dizinin zaman sırasıyla aynı olması için $t_n > t_{(n-1)}$ gerekir. Bu, $T > \epsilon_{(n-1)} - \epsilon_n$ koşuluna indirgenir; farkın desteği $(-2pT, 2pT)$ olduğundan yeterli koşul **$T > 2pT$, yani $p < 0.5$** 'tir. Aynı koşul, üçgensel IAT desteğinin pozitif kalmasını da sağlar. $p \geq 0.5$ durumunda olay sıralaması bozulabilir ve "olay zamanı" yorumu geçersizleşir.
- $Var(IAT) = 2\sigma_\epsilon^2$. Ardışık IAT'ler bağımsız değildir: ortak ϵ_n terimi nedeniyle $Cov(IAT_n, IAT_{(n+1)}) = -\sigma_\epsilon^2$, dolayısıyla **lag-1 otokorelasyon $\rho_1 = -0.5$** olur. Bu sonuç; (i) ϵ_n iid, (ii) $Var(\epsilon) < \infty$, (iii) indekslenen olay sırasının fiziksel zaman sırasını koruması koşulları altında değişmezdir (invariant) ve jitter dağılımının biçiminden bağımsızdır. Olaylar fiziksel zamana göre yeniden sıralanırsa, gözlenen IAT dizisi bu yapıyı korumayabilir.
- **Spektral sonuç (yer değiştirmiş kafes / displaced lattice)**: PSD iki bileşenden oluşur: (i) k/T noktalarında kütleli $|\Phi_\epsilon(k/T)|^2$ ile orantılı atomlar ve (ii) yoğunluğu $(1 - |\Phi_\epsilon(f)|^2)$ ile orantılı sürekli bir bileşen. Jitter ortadan kalktıkça ($\epsilon \rightarrow 0, \Phi_\epsilon \rightarrow 1$) sürekli bileşen kaybolur ve saf çizgi spektrumu elde edilir; jitter genişliği arttıkça atomlar zayıflar ve sürekli bileşen baskın hale gelir. $\Phi_\epsilon(f) = \text{sinc}(2\pi pTf)$ (normalize edilmemiş sinc, Bölüm 2.4) olduğundan atom kütleleri $2pk = m$, yani $k = m/(2p)$ koşulunda sıfırlanır; burada $m \in \mathbb{Z} \setminus \{0\}$. Ancak bu koşulun gerçekten bir çizgi atomunu yok etmesi için elde edilen k değerinin bir tamsayı harmonik indeksine denk gelmesi gerekir: k tamsayı değilse ortada yok edilecek bir çizgi yoktur. Bu sıfırlanma **yalnızca Model A'nın çizgi bileşenine** aittir.

Model B — Aralık (interval) jitter. Jitter, aralığın kendisine eklenir:

$IAT_n = T + U_n$, U_n iid, $E[U] = 0$, $Var(U) = \sigma_U^2$
 Uniform jitter örneği: $U_n \sim \text{Uniform}(-pT, pT)$
 $t_n = \sum_{i \leq n} IAT_i$ (kümülatif)

Sonuçlar:

- Genel iid U için IAT_n 'in dağılımı, U 'nun dağılımının T kadar ötelenmiş hâlidir; yani üniformluk **yalnızca $U_n \sim \text{Uniform}(-pT, pT)$ seçiminde** geçerlidir. Bu örnekte IAT_n , $[T - pT, T + pT]$ üzerinde üniformdur ve bağımsızdır.
- **Pozitiflik koşulu**: Yenilenme sürecinin geçerli olması için aralıkların neredeyse kesin pozitif olması gerekir: $P(T + U_n > 0) = 1$. Üniform örnekte bu, $T - pT > 0$, yani **$p < 1$** koşuluna karşılık gelir.
- Olay zamanları bağımsız artışların kümülatif toplamıdır: süreç bir **yenilenme (renewal) sürecidir**; faz (faz kayması) rastgele yürüyüş gibi birikir.
- Spektral sonuç: sürekli (lattice olmayan) aralık dağılımına sahip bir yenilenme sürecinde $f \neq 0$ için spektrum **mutlak sürekli**; **çizgi bileşeni yoktur**. Sürekli spektral yoğunluk, yenilenme PSD ifadesiyle verilir: $S(f) = \lambda \cdot (1 - |\psi(f)|^2) / |1 - \psi(f)|^2$; burada $\lambda = 1/T$ hız, $\psi(f)$ aralık dağılımının karakteristik fonksiyonudur. $f = 0$ atomu ortalamadan gelir. Aralık dağılımı T noktasına dejenere oldukça sürekli spektrum k/T çizgilerine daralır; periyodik spektrum bu dejenere limitin sonucudur.

Model ayrımı (kritik uyarı). İki model aynı jitter dağılımını kullansa bile farklı spektral yapı üretir: Model A'da çizgi atomları ile sürekli bir bileşen bir arada bulunur; Model B'de $f \neq 0$ için yalnızca sürekli spektrum vardır. Dolayısıyla "iki modelin ortak spektral sıfırları" biçiminde bir ifade geçersizdir: Model B'de sıfırlanacak çizgi bileşeni yoktur; Model A'da gözlenen sıfırlanma yalnızca çizgi atomlarına aittir. Aynı nedenle **bir modelin IAT dağılımını diğer modelin spektral sonucuyla birleştirmek matematiksel olarak geçersizdir**; bu tür bir birleştirme hem dedektör eşliğini hem de teorik gerekçeyi bozar.

2.3 Üstel Jitter ve Bellek Yoksunluğunun Kapsamı

Üstel jitter, sıfır ortalamalı bir model değildir: $Y \sim \text{Exp}(\lambda)$ için $E[Y] = 1/\lambda$ ve $Var(Y) = 1/\lambda^2$. Bu nedenle üstel jitter, Bölüm 2.2'deki $E[\cdot] = 0$ varsayımıyla birlikte kullanılamaz. Doğru kurulum ve doğru bellek yoksunluğu ifadesi:

$X = T + Y$, $Y \sim \text{Exp}(\lambda)$, $\text{destek}(X) = [T, \infty)$
 Fazlalık değişkeni : $Y = X - T$
 Bellek yoksunluğu : $P(Y > y + t \mid Y > y) = P(Y > t) = e^{(-\lambda t)}$
 Eşdeğer ifade : $P(X > s + t \mid X > s) = e^{(-\lambda t)}$, $s \geq T$

Kritik ayırım: bellek yoksunluğu Y'ye aittir, X'e ait değildir. $P(X > s+t \mid X > s) = P(X > t)$ ifadesi yanlıştır; X kaydırılmış olduğu için $P(X > t) = e^{(-\lambda(t-T))}$ olur ve $s \geq T$ koşulu altında bu, $e^{(-\lambda t)}$ değerine eşit değildir. Ayrıca X'in desteği T'de başladığı için dağılımın alt sınırı keskin kalır; bu sınır, gözlemlenebilir bir özelliktir.

2.4 Sinc Konvansiyonu

Literatürde iki farklı sinc tanımı kullanılır ve bunların karıştırılması sayısal sonuçları doğrudan bozar. Bu raporda:

Normalize edilmemiş (bu raporda kullanılan): $\text{sinc}(x) \equiv \sin(x) / x$, $\text{sinc}(0) = 1$
 Normalize edilmiş (kullanılmaz): $\text{sinc}_N(x) \equiv \sin(\pi x) / (\pi x)$

$\Phi(f) = \text{sinc}(2\pi f T_f)$ yazımı, normalize edilmemiş konvansiyona göredir. Normalize konvansiyonla bu ifade $\text{sinc}_N(2\pi f T_f)$ biçiminde yazılmalıdır. Metinde sinc geçen her yerde bu tanım geçerlidir.

2.5 Tespit Tavanı İddiasının Sınırlandırılması

Raporun hiçbir bölümünde "akış düzeyinde hiçbir ayırt edici iz kalmaz" biçiminde bilgi-teorik bir yokluk iddiası kurulmamaktadır. Sınırlı ve savunulabilir ifade şudur:

> Bu raporda değerlendirilen özellik ailesi — marjinal IAT/hacim dağılımı, güç spektral yoğunluğu, otokorelasyon yapısı, Hurst üsteli ve diyurnal profil — için sınıflar arası ayırım belirgin biçimde azalabilir veya çökebilir.

Bu ifade, aşağıdaki akış düzeyi özellik ailelerinin ayırım gücünü koruyabileceğini açıkça kabul eder:

- **Yüksek mertebeden bağımlılık:** İkinci momentle sınırlı olmayan, doğrusal olmayan bağımlılık ölçüleri (örneğin koşullu yoğunluk tabanlı testler, uzun hafıza parametresinin farklı mertebelerden kestirimi).
- **Multifraktal spektrum:** $h(q)$ genişliği ve moment ölçekleme davranışı (Bölüm 3.3).
- **Akışlar arası korelasyon:** Aynı host veya aynı iş yükü sınıfındaki akışların ortak zamanlama bileşenleri.
- **Uygulama/protokol tutarlılığı:** TLS kayıt boyu dağılımı, JA4 parmak izi, HTTP/2 akış davranışı gibi protokol düzeyi artefaktlar (Bölüm 6.11).
- **Nedensellik katmanı:** Akışı üreten sürecin oturum ve yetki bağlamı (Bölüm 6.7–6.9).

Bu nedenle "tespit tavanı" ifadesi, rapor boyunca **değerlendirilen özellik ailesi için** geçerli bir sınır olarak okunmalıdır; genel bir yokluk teoremi olarak değil.

2.6 Süperpozisyon ve Asimptotik Koşullar

Poisson benzeri görünüm, çok sayıda bağımsız yenilenme sürecinin süperpozisyonunda ortaya çıkar (Palm–Khinchine teoremi). Bu yakınsama koşulsuz değildir; geçerli olduğu rejim şu üç koşulla tanımlanır:

1. **Bağımsızlık:** Süperpoze edilen kaynaklar birbirinden bağımsız olmalıdır.
2. **Baskın kaynak yokluğu (no-dominant-source):** Hiçbir kaynağın toplam hıza katkısı, süperpozisyonun bütününe belirleyecek düzeyde olmamalıdır. Tek bir kaynak toplam hızın belirgin bölümünü taşıyorsa, toplulaştırılmış süreç o kaynağın yapısal özelliklerini korur.
3. **Nadir kaynak rejimi (rare-source):** Bireysel kaynak hızları, toplam hıza göre küçük kalmalı ve kaynak sayısı artarken bireysel hızlar sınırlı olmalıdır.

Bu koşullar sağlanmadığında süperpozisyon Poisson'a yakınsamaz; baskın bir kaynağın varlığı veya sınırlı sayıda kaynağın toplanması, öz-benzerlik dâhil kaynak yapısının toplulaştırılmış trafikte görünür kalmasına yol açar. Savunma açısından sonuç: toplulaştırılmış akış analizinde "Poisson görünümü" bir varsayım değil, doğrulanması gereken bir hipotezdir.

2.7 Makine Öğrenmesi Tabanlı Tespitin Sınırları

Bazı ağ anomalilik tespiti araştırmaları autoencoder ailesini kullanır (bkz. Ek D: An ve Cho, 2015; Mirsky vd., 2018; Chalapathy ve Chawla, 2019). **Autoencoder tabanlı anomalilik modelleri normal örneklerin temsiliyi öğrenir ve reconstruction error üzerinden anomali üretir.** Belirli bir özellik kümesi (örneğin IAT histogramı) veya belirli bir mimari (1D-CNN, LSTM) bu kaynakların doğrudan iddiası değildir. CNN/RNN tabanlı trafik sınıflandırıcıları farklı bir problem sınıfına aittir: anomali üretmez, etiketli sınıflara ayırma yaparlar (Lopez-Martin vd., 2017; Boutaba vd., 2018). Model A (olay-zamanı jitter) uygulanmış bir beacon bu temsil uzayında:

- **Uniform-jitter Model A örneğinde** IAT marjinal dağılımı simetrik üçgenseldir; dağılım tabanlı dedektörler için örtüşmesi zor bir imzadır, ancak teorik gerekçe dağılım biçimine değil bağımlılık yapısına dayandırılmalıdır.
- Spektral olarak çizgi yapısını korur; tepe frekansı değişmez, genlik $|\Phi_\epsilon|$ oranında zayıflar.
- Lag-1 otokorelasyonu -0.5 civarındadır; bu, bağımsız aralıklı süreçlerden ayırt edici bir aday özelliktir.

Model B (aralık jitter) uygulanmış bir beacon ise bağımsız IAT dizisi üretir ve spektrumunda $f \neq 0$ için çizgi bileşeni bulunmaz; bu durumda ayırım, sürekli spektrumun biçimi, IAT desteğinin keskinliği ve kuyruk davranışı üzerinden kurulur. İki modelin dedektör gereksinimleri farklıdır; bu nedenle jitter'a ilişkin tespit mantığı kurulurken model açıkça belirtilmelidir.

3. Kurumsal Trafiğin İstatistiksel Parmağı: Öz-Benzerlik ve Uzun Menzilli Bağımlılık

3.1 Ölçekleme Yasası ve Hurst Üsteli

Kurumsal ağ trafiğinin istatistiksel doğası, 1990'lı yılların başından itibaren ağ mühendisliği literatüründe yerleşik bir bulgu olarak tanımlanmıştır. Leland ve arkadaşlarının (1994) Ethernet trafiği ölçümleri ile Paxson ve Floyd'un (1995) geniş alan ağı ölçümleri, trafiğin Poisson varsayımıyla uyumsuz olduğunu göstermiştir. Ölçülen Ethernet/WAN trafik izleri, farklı zaman ölçeklerinde istatistiksel olarak kendine benzer davranış göstermiştir; bu izlerde Hurst üsteli uzun menzilli bağımlılık rejiminde ($H > 0.5$) ölçülmüştür. Bu, tüm ağ trafiği için evrensel bir özellik değil, ölçüm bağlamına bağlı ampirik bir bulgudur.

Öz-benzerlik, toplulaştırma (aggregation) altındaki davranışla tanımlanır. Bir süreç, m düzeyinde toplulaştırıldığında dağılımı (uygun ölçekleme sonrası) değişmiyorsa öz-benzerdir:

$$X^{(m)}[k] = (1/m) \cdot \sum_{i=(k-1)m+1}^{km} X[i]$$

$$X^{(m)} \approx m^{(H-1)} \cdot X \quad (\text{dağılım eşitliği, uygun normalizasyonla})$$

Poisson süreci bu testi geçemez: toplulaştırma arttıkça beyaz gürültüye düzleşir, varyansı $1/m$ hızıyla azalır. Uzun menzilli bağımlılık rejiminde varyans $m^{(2H-2)}$ hızıyla azalır; sönmüleme hızı H değerine bağlıdır ve H büyüdükçe bellek etkisi uzar. Fark, ölçüm penceresi büyüdükçe kapanmak yerine açılır.

Toplulaştırılmış sayım/oran serisi ile kümülatif süreç ayırımı. Bu ayırım, ölçüm tasarımı açısından belirleyicidir:

Nesne	Tanım	İstatistiksel rolü
Kümülatif süreç	$Y(t) = \sum_{i: t_i \leq t} X_i$	Süreç durağan değildir; artışları durağandır. fBm benzeri davranış burada tanımlanır
Toplulaştırılmış sayım/oran serisi	m uzunluğunda pencerelerde sayım veya ortalama	Durağan artışlı; fGn benzeri davranış burada tanımlanır

Dedektörler pratikte toplulaştırılmış seriler üzerinde çalışır. Bu nedenle ölçekleme üsteli kestirimi yapılırken hangi nesnenin örneklendiği açıkça belirtilmelidir; kümülatif süreç üzerinde hesaplanan bir kestirici ile pencere ortalamaları üzerinde hesaplanan kestirici aynı sayıyı vermez.

3.2 Ağır Kuyruklar ve Kaynak Modeli

Öz-benzerliğin kaynağı konusunda literatürde tek bir açıklama yoktur. Ağır kuyruklu kaynak davranışı, gözlenen öz-benzerliği üretmek için **güçlü ve yeterli** bir mekanizmadır. Willinger ve arkadaşlarının ON/OFF modelinde her

kaynak, açık (ON) ve kapalı (OFF) dönemler arasında geçiş yapar ve bu dönemlerin süreleri ağır kuyruklu (heavy-tailed) dağılıma sahiptir; bu kaynakların süperpozisyonu LRD üretir. Ancak bu, tek açıklama değildir: çoklu ölçekli çoklama ve geri beslemeli akış kontrolü, uygulama düzeyi istek/yanıt kümelenmesi, durağan olmayan yoğunluk bileşenleri ve ölçüm/örnekleme artefaktları da öz-benzerliğe katkı verebilir. Bu nedenle kaynak davranışı, ağ katmanındaki çoklamanın tek başına yeterli olmadığını gösterir; fakat ağır kuyruğun tek olası mekanizma olduğu iddiasını kurmaz.

$$P(\text{ON süresi} > x) \sim x^{-(\alpha)}, \quad 1 < \alpha < 2$$

$$H = (3 - \alpha) / 2$$

$1 < \alpha < 2$ aralığında **ON/OFF faz süresi değişkeninin** beklenen değeri sonludur; ıraksayan bu değişkenin ikinci momentidir (varyansdır). Hangi değişkenin ıraksadığı açık olmalıdır: ağır kuyruk, kaynak faz sürelerinin (ON ve OFF dönem uzunluklarının) özelliğidir; normalize edilmiş limit sürecin (fBm) varyansı sonludur ve ağır kuyruk limitte uzun menzilli bağımlılık olarak tezahür eder. Operasyonel sonuç doğrudandır: faz süresi gözlemlerinde örneklem varyansı yakınsamaz, dolayısıyla bu değişken üzerinde kurulan varyans ve standart sapma tabanlı eşikler kararsızdır; $\alpha \leq 1$ durumunda faz süresinin beklenen değeri de ıraksar.

Kuyruk indeksi kestiriminde ölçüm araçlarının rolü ayrıştırılmalıdır. Log-log CCDF eğrisi öncelikle **tanısal** bir araçtır: kuyruk düzgünlüğünü, olası kesilme noktalarını ve rejim değişimlerini görselleştirir. Hill kestiricisi ise dağılımın **düzenli değişen (regularly varying) kuyruk** varsayımı altında tutarlıdır ve sonucu eşik/k seçimine duyarlıdır. Bu nedenle kestirim öncesi ve sonrasında şu adımlar gereklidir: (i) log-log CCDF üzerinde düzgün bölgenin belirlenmesi, (ii) Hill çiziminin (Hill plot) k boyunca kararlılık tanınması, (iii) seçilen k için yanlılık-varyans ödünleşiminin raporlanması, (iv) farklı k değerlerinde kestirimin duyarlılığının gösterilmesi. Naif log-log CCDF regresyonu veya tek bir k değerinde hesaplanan Hill kestirimi, tercih edilen kestirici olarak sunulmamalıdır; bu yöntemler varsayım denetimi yapılmadan kullanıldığında yanıltıcı sonuç üretir.

Ağır kuyruk, kaynak süreçlerinin (ON/OFF fazlarının) özelliğidir. Bu kaynakların normalize edilmiş süperpozisyonunun limit süreci sonlu varyanslıdır; ağır kuyruk bu limitte uzun menzilli bağımlılık ve öz-benzerlik olarak tezahür eder. İki ifade çelişmez; farklı nesnelere aittir.

$H = (3 - \alpha)/2$ bağıntısı, kaynakların Pareto kuyruklu ON/OFF dönemlerle modellendiği ve süperpozisyonun uygun asimptotik rejimde değerlendirildiği limit modelde geçerlidir (Taqqu, Willinger ve arkadaşlarının ON/OFF süperpozisyon sonuçları). Başka kaynak modellerinde (örneğin sonlu momentli süreçler veya farklı kuyruk aileleri) bu bağıntı geçerli değildir; α ile H arasındaki ilişki model bağımlıdır.

3.3 Multifraktalite

Tek bir Hurst üsteli, trafiğin tüm ölçek davranışını açıklamaz. Kurumsal trafik izleri multifraktal davranış sergileyebilir: farklı momentler farklı ölçekleme üstelleri gösterebilir. Bu, dalgacık lideri (wavelet leader) analizi veya MF-DFA ile $h(q)$ spektrumunun genişliği üzerinden ölçülür. Multifraktalite, rejim değişimlerine özgü tekil bir imza değildir: çoklu ölçekli çoklama, ağır kuyruklu marjinaler, durağan olmayan bileşenler ve ölçüm artefaktları da multifraktal görünüm üretebilir. Bu nedenle $h(q)$ genişliği tek başına bir sınıflandırma gerekçesi değil, aday bir özelliktir.

Tespit açısından iki sonucu vardır:

- **Monofraktal sapma (aday özellik):** Tek parametrelili modellerle üretilen trafikte $h(q)$ spektrum genişliği baseline'a göre daralabilir. Spektrum genişliği, ölçekleme üstelinden bağımsız bir aday özelliktir; ancak iş yükü sınıfına göre değiştiği için tek başına kanıt değeri taşımaz.
- **Modelleme maliyeti (teorik):** Multifraktal yapının taklidi, tek bir stokastik modele değil, rejim geçişleri arasındaki bağımlılık yapısına da modelleme gerektirir. Bu, bir tespit özelliği değil, karşı tarafın mühendislik yüküne ilişkin bir değerlendirmedir.

3.4 Savunma Açısından Anlamı

Öz-benzerlik ve LRD, savunma tarafına iki yapısal imkân sunar. Birincisi, uzun gözlem ufuklarında ölçekleme parametrelerinin kestirimi kararlı hale gelir; kısa pencerelerde gürültü içinde kaybolan ayrımlar, uzun pencerelerde

istatistiksel olarak anlamlı düzeye çıkar. İkincisi, bu parametreler yalnızca tek bir akışa değil, bir host'un tüm akış rejimine bağlıdır; bu nedenle host düzeyinde toplanabilir ve karşılaştırılabilir.

Uyarı: bu iki imkân, pencere uzunluğunun artırılmasının maliyetsiz olduğu anlamına gelmez. Pencere uzunluğu; örnekleme oranı, iş yükünün durağanlığı, kestiricinin yanlışlık/varyans davranışı ve mevsimsel yapı tarafından belirlenir (Bölüm 8.4).

4. Kapsam Sınırı ve Operasyonel Olmayan Model Bağlamı

4.1 İfşa Politikası

Bu raporun konusu C2 trafiğinin tespiti; üretimi değildir. Bu ayırım bilinçli bir kapsam kararıdır ve üç nedene dayanır:

- **İfşa riski:** Zamanlama şekillendirme, taşıyıcı seçimi ve kalibrasyon adımlarına ilişkin uygulama düzeyi ayrıntılar, savunma amacıyla paylaşıldığında saldırı kapasitesine dönüşebilir.
- **Savunma değeri:** Tespit kapasitesi, karşı tarafın iç işleyişine değil, gözlemlenebilir çıktıların istatistiksel ve nedensel özelliklerine dayanır.
- **Kalıcılık:** Üretim yöntemleri hızla değişir; gözlemlenebilir imzalar ve telemetri bağımlılıkları daha yavaş değişir.

Bu bölüm, dedektör gerekçelerinin dayandığı model bağlamını **tanımlayıcı düzeyde** verir. İçermediği şeyler: dağıtılabilir jeneratör kodu, hedef ortamdan parametre çıkarımı prosedürü, kaçınma reçetesi, sızdırma optimizasyonu, herhangi bir operasyonel parametre seti.

4.2 Model Taksonomisi

Model sınıfı	Faz (sojourn) süresi	Bağımlılık	Tipik ölçekleme	Dedektör varsayımına etkisi
Klasik MMPP (Markov-Modüleli Poisson Süreci)	Üstel	Kısa menzilli (SRD)	$H \approx 0.5$	Otokorelasyon hızlı söner; pencere ortalamaları hızlı yakınsar
Yarı-Markov / ağır kuyruklu modüleli süreç	Ağır kuyruklu (ıraksayan, faz süresi değişkeninin varyansıdır)	Uzun menzilli (LRD)	$H > 0.5$	Faz süresi varyansı yakınsamaz; kuyruk kestiricileri gerekir
ON/OFF kaynak süperpozisyonu (Pareto dönemler)	Ağır kuyruklu	LRD (fBm limiti)	$H = (3 - \alpha)/2$	Ölçekleme, pencere uzunluğuna duyarlıdır

Bu taksonomi, dedektör tasarımında üç farklı davranış rejimini ayırt etmek için kullanılır: kısa menzilli (hızlı sönen otokorelasyon), uzun menzilli (yavaş sönen otokorelasyon) ve limit süreç davranışı. Bir dedektörün eşiği, hangi rejimde çalıştığı bilinmeden anlamlı biçimde kurulamaz.

Kısa menzilli ve uzun menzilli bağımlılık. Otokorelasyon fonksiyonu $\rho(k)$ için:

SRD: $\sum_k |\rho(k)| < \infty$ (toplanabilir; tipik olarak üstel sönüm)
 LRD: $\sum_k |\rho(k)| = \infty$ (toplanamaz; tipik olarak $k^{-(2H-2)}$ sönümü)

Pratik sonuç: LRD rejiminde pencere ortalamaları arasındaki korelasyon, pencere büyüdükçe beklenen hızda kaybolmaz. Bu nedenle "yeterince uzun pencere alırsak bağımsız örneklem elde ederiz" varsayımı bu rejimde geçersizdir; istatistiksel testlerin serbestlik derecesi yanlış hesaplanır.

4.3 fBm ve fGn Ayırımı

Öz-benzer süreçlerde iki farklı nesne sık karıştırılır:

fBm (fraksiyonel Brown hareketi) : kümülatif süreç; süreç durağan DEĞİLDİR, artışları durağandır
 fGn (fraksiyonel Gauss gürültüsü) : fBm'in durağan artış süreci; durağan

Ayrımın operasyonel anlamı:

- **fBm** kümülatif süreçtir (örneğin toplam bayt sayısı). Durağan olmadığı için doğrudan spektral yoğunluk analizine sokulmaz.
- **fGn** durağan artış sürecidir (örneğin pencere başına sayım veya ortalama). Spektral analiz bu nesne üzerinde yapılır.
- $\beta = 2H - 1$ bağıntısı, durağan artışlı (fGn benzeri) serinin düşük frekans güç spektral davranışı için kullanılır. Bu ifade, "fBm'in güç spektral yoğunluğu" olarak sunulmamalıdır; fBm durağan olmadığı için klasik anlamda bir PSD'ye sahip değildir.
- Ölçüm pratiğinde, pencere ortalamaları üzerinden kestirilen H , kümülatif seriden kestirilen değerle aynı olmak zorunda değildir; iki kestirim raporlanırken nesne açıkça belirtilmelidir.

4.4 Dedektör Varsayımlarının Model Karşılığı

Aşağıdaki tablo, yaygın dedektör ailelerinin hangi model özelliğine dayandığını ve hangi rejimde geçersizleştğini özetler.

Dedektör ailesi	Dayandığı model özelliği	Geçersizleştirdiği rejim
Sabit periyot / FFT tepe araması	Olay treninde ayırk spektral çizgi	Sürekli PSD'ye geçiş
IAT varyansı / standart sapma eşiği	İkinci momentin sonlu ve yakınsak olması	Yalnızca ölçülen değişkenin kendisi $1 < \alpha < 2$ aralığında ağır kuyruklu olduğunda: bu durumda örneklem varyansı yakınsamaz
Otokorelasyon tabanlı periyodiklik	Kısa menzilli, periyodik bağımlılık	LRD rejimi
Pencere ortalaması karşılaştırması	Örneklemelerin yaklaşık bağımsızlığı	LRD rejimi (serbestlik derecesi hatası)
Marjinal dağılım eşleştirmesi	Sınıflar arası marjinal farklılık	Marjinal örtüşmesi
Entropi tabanlı sınıflandırma	Dağılım belirsizliğindeki fark	Aynı entropiyi üreten farklı dağılımlar

Not: Örneklem varyansının yakınsamaması, yalnızca ölçülen değişkenin kendisinin $1 < \alpha < 2$ aralığında ağır kuyruklu olması durumunda geçerlidir. Bu koşul sağlanmıyorsa, varyans tabanlı eşikler bu gerekçeyle geçersiz sayılmaz; geçersizlik iddiası ölçülen değişkenin kuyruk yapısına bağlı olarak kurulmalıdır.

Bu tablo, tespit tavanının neden bir "yöntem yokluğu" değil, **varsayım-rejim uyumsuzluğu** olduğunu gösterir: dedektörler yanlış çalışmaz, yanlış rejimde çalıştırılır.

5. Tespit Tavanının Kapsamı

5.1 Özellik Uzayının Durumu

NDR ürünlerinin akış düzeyi özellik uzayı tarihsel olarak şu bileşenlerden oluşur: periyot düzenliliği, IAT varyansı, bayt hacmi dağılımı, hedef çeşitliliği (fan-out), oturum süresi ve bunların türevleri. Profil uyumlu C2 trafiği varsayımı altında bu uzayın durumu tablo halinde özetlenebilir.

Özellik Grubu	Sabit Beacon	Jitter'lı Beacon (Model A / B)	Profil Uyumlu C2
Spektral tepe	Belirgin	Zayıflamış, konumu korunur	Değerlendirilen ailede yok
IAT marjinal dağılımı	Deterministik	Uniform jitter örneğinde: üçgensel (A) / üniform (B)	Baseline dağılımı ile örtüşür
Otokorelasyon	Periyodik	$\rho_1 = -0.5$ (A) / bağımsız (B)	Yavaş sönümlü (LRD)
Ölçekleme (H)	Tanımsız	Kısa menzilli ($H \approx 0.5$)	Baseline bandında (LRD)
PSD eğimi	Ayrık tepe	Çizgi atomları ve sürekli bileşen bir arada (A) / sürekli, ayırk çizgi yok, biçimi $\psi(f)$ 'ye bağlı (B)	Sürekli, $1/f^\beta$ benzeri
Diyurnal profil	Yok	Yok	Baseline ile hizalı

Tablodan çıkan sonuç, Bölüm 2.5'te sınırlandırılmış biçimde ifade edilmelidir: **bu özellik ailesi için** sınıflar arası ayırım belirgin biçimde azalabilir. Tablo, ayırımın hiçbir koşulda mümkün olmadığı anlamına gelmez.

5.2 Klasik Dedektörlerin Yapısal Yanılgıları

Kurumsal ölçekte yaygın üç dedektör sınıfı, profil uyumlu C2 varsayımı altında sistematik olarak zayıflar:

- **Eşik tabanlı IAT dedektörleri:** $\text{std}(\text{IAT}) > \sigma$ gibi kurallar, jitter'lı beacon'ı yakalayabilir ancak ağır kuyruklu meşru trafikte yüksek yanlış pozitif üretir. Eşik yükseltildiğinde profil uyumlu trafik de görünmez hale gelir. Sorun, tek boyutlu bir eşik'in iki boyutlu bir gerçekliğe uygulanmasıdır.
- **Periyodiklik dedektörleri:** Otokorelasyon veya FFT tepe araması, ayrık çizgi içermeyen sürekli spektruma karşı yapısal olarak zayıftır.
- **Entropi tabanlı dedektörler:** Entropi, dağılımın şeklini değil belirsizliğini ölçer. Farklı dağılımlar aynı entropi değerini üretebilir; bu nedenle entropi tek başına ayırt edici değildir.

5.3 Etiketleme Sorunu ve Konsept Kayması

Akış düzeyi tespiti ikinci yapısal sorunu, denetimli öğrenme varsayımlarıdır. Kurumsal ölçekte etiketli C2 örnekleme üç nedenden ötürü temsil gücünü yitirir: (i) gerçek profil uyumlu C2 örnekleri nadirdir ve paylaşılmaz, (ii) mevcut etiketler eski nesil beacon davranışına aittir, (iii) meşru trafik baseline'ı kurumsal değişimlerle (bulut geçişi, uzaktan çalışma, yeni hizmet entegrasyonları) sürekli kayar. Sonuç, modelin ya aşırı uyum (overfitting) ya da sürekli yanlış pozitif üretmesidir.

5.4 Kalan Ayırım Yüzeyleri

Değerlendirilen özellik ailesindeki ayırım azalsa bile aşağıdaki yüzeyler savunma değeri üretmeye devam eder:

- Yüksek mertebeden ve doğrusal olmayan bağımlılık ölçüleri.
- Multifraktal spektrum genişliği ve moment ölçekleme davranışı.
- Akışlar arası ve host'lar arası ortak zamanlama bileşenleri.
- Uygulama/protokol tutarlılığı (TLS kayıt boyu, JA4, HTTP/2 davranışı).
- Zamanlayıcı ve uygulama katmanı artefaktları (Bölüm 6.4, 6.10).
- Süreç, oturum ve yetki bağlamı (Bölüm 6.7–6.9).

Raporun taktik bölümü bu yüzeyler üzerine kuruludur.

6. Taktik Kataloğu (T1 – T20)

Bu bölümdeki yirmi taktik, Bölüm 5.4'te tanımlanan kalan ayırım yüzeyleri üzerine kuruludur. Her taktik dokuz alanla tanımlanır: yüzey, veri kaynağı, hipotez, matematiksel/operasyonel gerekçe, karıştırıcı faktörler (confounders), yanlış pozitif kaynakları, gerekli baseline, önerilen validasyon yöntemi ve kanıt gücü.

Kanıt gücü ölçeği:

- **Tek başına:** Ölçüm, ilgili bağlamda kendi başına triyaj edilebilir bir sinyal üretir.
- **Korelasyon gerektirir:** Ölçüm tek başına kanıt değeri taşımaz; en az bir bağımsız düzlemle (uç nokta, kimlik, protokol) birleştirilmelidir.
- **Korelasyon altyapısı:** Ölçüm kendisi tehdit kanıtı üretmez; diğer taktiklerin kanıt değerini yükselten bir altyapı sağlar. Bu sınıftaki bir bileşenin çalışıyor olması hiçbir koşulda tek başına tehdit göstergesi olarak raporlanmaz.

Raporda hiçbir taktik "kesin tespit" olarak tanımlanmaz. Taktikler aday özellik üretir; karar analist triyajına aittir.

6.1 T1 — Kayan Pencere Ölçekleme Kararlılığı

- **Yüzey:** Ağ.
- **Veri Kaynağı:** Akış kayıtları (IPFIX/NetFlow v9, bağlantı kayıtları); pencere başına bayt sayımı veya oturum sayımı.
- **Hipotez:** Belirli bir iş yükü sınıfında, insan kaynaklı trafikte ölçekleme üsteli kestirimi günler arasında dalgalanır; algoritmik olarak üretilen trafikte kestirim baseline bandı içinde anormal biçimde kararlı kalır.

- **Gerekçe:** LRD rejiminde kestiricinin pencereye bağlı davranışı, dışsal olaylarla (tatil, kesinti, sürüm geçişi) kırılır. Sabit parametrelili üretim bu kırılmaları üretmez. Bu bir istatistiksel beklentidir, matematiksel bir zorunluluk değildir.
- **Confounders:** İş yükü sınıfı farkları (sunucu/istemci), hafta sonu etkisi, uzaktan çalışma düzeni, yedekleme pencereleri, kestiricinin kendi yanlılığı.
- **Yanlış Pozitif Kaynakları:** Yönetim ajanları, sürekli düşük hacimli telemetri akışları, otomasyon hesapları, kiosk cihazları.
- **Gerekli Baseline:** İş yükü segmenti başına, en az bir çeyrek dönem; kestiricinin varyansı baseline'dan ölçülmelidir.
- **Validasyon:** Bilinen sabit profilli bir test akışı (kurum kontrollü simülatör, T15) ile dedektörün yanıt eğrisi ölçülür; ayrıca meşru segmentlerde yanlış pozitif oranı raporlanır.
- **Kanıt Gücü:** Korelasyon gerektirir.

6.2 T2 — Kuyruk Yapısı ve Hill Kestirici Sapması

- **Yüzey:** Ağ.
- **Veri Kaynağı:** Oturum/akış büyüklükleri; paket düzeyi erişilebilirse patlama süreleri.
- **Hipotez:** Ağır kuyruklu meşru trafikte $\alpha_{Hill}(k)$ eğrisi artan k ile yumuşak davranır; kırılmış kuyruk yapısında eğri belirli bir k sonrasında sistematik sapma gösterir.
- **Gerekçe:** Ağır kuyrukta örneklem varyansı yakınsamaz; bu nedenle kuyruk kestirimi, düzenli değişen kuyruk varsayımı ve eşik/ k seçimi denetlenerek Hill kestiricisi ile yapılır; log-log CCDF eğrisi tanısal amaçla kullanılır (bkz. Bölüm 3.2). Kırpma, CCDF eğrisinin üst ucunda düzleşme ve ani düşüş üretir.
- **Confounders:** Protokol sınırları (TLS kayıt boyu, HTTP/2 pencere boyutu), uygulama tampon politikaları, MTU etkisi, NIC offload, sıkıştırma.
- **Yanlış Pozitif Kaynakları:** Yedekleme işleri, dosya paylaşımı, medya akışı, CDN davranışı; protokol kaynaklı doğal üst sınırlar.
- **Gerekli Baseline:** Uygulama/protokol sınıfı başına ayrı CCDF baseline'ı; segment bazında.
- **Validasyon:** Baseline'daki bilinen kesilme noktaları (protokol sınırları) ile gözlemlenen sapmanın karşılaştırılması; sentetik kesilmiş dağılımlarla eşik kalibrasyonu.
- **Kanıt Gücü:** Korelasyon gerektirir.

6.3 T3 — Kuantizasyon ve Tarak Deseni (Aday Özellik)

- **Yüzey:** Ağ (paket düzeyi).
- **Veri Kaynağı:** Paket düzeyi zaman damgaları; TAP/SPAN beslemeli paket sensörü. Bağlantı kayıtları bu ölçüm için yetersizdir.
- **Hipotez:** Gönderim zamanlaması bir zamanlayıcı mekanizmasına bağlı olduğunda, IAT dağılımı ilgili kuantumun katlarında yığılma gösterebilir; bu yığılma host/build/segment baseline'ına göre ölçülebilir bir aday özelliktir.
- **Gerekçe:** Zamanlayıcı tabanlı uyku ve gönderim, işletim sistemi ve çalışma zamanı katmanındaki çözünürlük ve birleştirme (coalescing) politikalarına bağlıdır. Ölçüm, bu mekanizmanın bıraktığı istatistiksel izi arar. Gerekçe **heuristic**'tir; matematiksel bir zorunluluk değildir.
- **Confounders:** Yüksek çözünürlüklü zamanlayıcılar ve uygulamanın zamanlayıcı çözünürlüğü talebi; işletim sistemi güç/scheduler politikaları; çalışma zamanı olay döngüsü tasarımı; TCP pacing; NIC kesme birleştirme (interrupt coalescing); VM/hypervisor zamanlama sapması; VPN/NAT gecikme dağılımı; yakalama sisteminin zaman damgası kaynağı (NIC donanım damgası, çekirdek damgası, kullanıcı alanı damgası) ve saat disiplini (NTP/PTP).
- **Yanlış Pozitif Kaynakları:** Medya akışları (sabit kare süreleri), yoklama tabanlı izleme, VoIP, gerçek zamanlı kontrol trafiği, sanallaştırılmış toplayıcılar.
- **Gerekli Baseline:** Segment ve iş yükü sınıfı bazında IAT/faz histogramı; sensör zaman damgası kaynağının belgelenmesi.
- **Validasyon:** Aynı segmentte bilinen zamanlayıcı davranışına sahip kurum içi bir uygulama ile karşılaştırma; sentetik veri ile eşik taraması; sensör saat doğruluğunun bağımsız ölçümü.

- **Kanıt Gücü:** Korelasyon gerektirir. Tek başına sinyal, triyaj için yeterli değildir.
- **Not:** Bu taktikin eşikleri (faz toleransı, edge_share, ki-kare değeri) sabit değildir; kurum, host ve derleme baseline'ından türetilmelidir (Bölüm 7.4).

6.4 T4 — Host'lar Arası Ortak Parametre Kümesi

- **Yüzey:** Ağ (+ kimlik).
- **Veri Kaynağı:** Host başına çıkarılan ölçekleme ve kuyruk özetleri; envanter ve kimlik verisi ile zenginleştirme.
- **Hipotez:** Farklı iş birimlerinde, farklı coğrafyalarda ve farklı iş yüklerinde bulunan host'ların istatistiksel özetleri beklenenden yüksek benzerlik gösteriyorsa, ortak bir üretim veya yapılandırma kaynağı adaydır.
- **Gerekçe:** Meşru host'lar kendi kullanıcısı, lokasyonu ve iş yükü nedeniyle farklılaşır. Benzerlik bu nedenle bir aday özelliktir.
- **Confounders:** Standart kurumsal imaj ve aynı ajan sürümü, ortak VPN çıkış noktaları, aynı SaaS bağımlılıkları, ortak zaman dilimi.
- **Yanlış Pozitif Kaynakları:** Aynı donanım/işletim sistemi imajı, aynı EDR/RMM ajanı, toplu yapılandırma yönetimi.
- **Gerekli Baseline:** Segment ve rol bazlı özet dağılımları; benzerlik eşiği bu dağılımdan türetilir.
- **Validasyon:** Bilinen filo (örneğin aynı yazılım sürümünü çalıştıran test grubu) üzerinde kümelenme davranışının ölçülmesi.
- **Kanıt Gücü:** Korelasyon gerektirir.

6.5 T5 — Rejim Kayması ve Yapısal Kırılma Analizi

- **Yüzey:** Ağ.
- **Veri Kaynağı:** Host veya segment düzeyinde zaman serisi; pencere bazlı PSD ve otokorelasyon özetleri.
- **Hipotez:** Meşru trafik dışsal olaylarla kırılır; kırılma sayısı ve zamanlaması baseline ile karşılaştırıldığında sapma aday sinyaldir.
- **Gerekçe:** Durağanlık testleri (ADF, KPSS) ve yapısal kırılma testleri (CUSUM, Bai-Perron) pencere bazında uygulandığında rejim değişimlerinin sıklığını ölçer. Bu testler tek bir varsayım altında toplanamaz; her birinin standart asimptotik dağılımı kendi kısa-hafıza/zayıf bağımlılık koşullarına dayanır: ADF birim kök asimptotikleri kısa hafızalı (veya sonlu mertebeden) hata süreçleri için türetilmiştir; KPSS istatistiğinin sınır dağılımı kısa hafızalı durağanlık altında elde edilir; CUSUM-tipi kırılma testlerinin sınır dağılımları zayıf bağımlılık ve uygun mixing koşulları gerektirir; Bai-Perron çoklu kırılma prosedürü de kısa hafızalı, durağan hata ve regresör varsayımlarına dayanır. Uzun menzilli bağımlılık veya fraksiyonel bütünleşme ($d \in (0, 0.5)$) altında bu sınır dağılımları değişir ve klasik kritik değerler geçerliliğini yitirir; testler aşırı red veya aşırı kabul yönünde yanlış olabilir (bkz. Ek D: Baillie, 1996; Krämer, Sibbertsen ve Kleiber, 2002). Doğru yaklaşım, test-spesifik kalibrasyondur: uzun hafızaya duyarlı kritik değerler veya yeniden örnekleme (resampling) temelli kalibrasyon. Burada bir sınırlama açıkça belirtilmelidir: **LRD altında resampling yöntemi ayrıca doğrulanmalıdır; standart blok/stationary bootstrap (Künsch, 1989; Politis ve Romano, 1994) uzun hafızayı otomatik olarak koruyan bir çözüm değildir.** Bu kaynaklar genel durağan (kısa hafızalı/zayıf bağımlı) gözlemler için tutarlılık sağlar; uzun hafıza altında blok uzunluğu seçimi ve yeniden örneklenen serinin ölçekleme davranışı ayrıca gerekçelendirilmelidir. LRD altında geçerliliği gösterilmiş bir resampling yöntemi kullanılacaksa, o yöntemin kaynağı ve geçerlilik koşulları bu raporda ayrıca belirtilmelidir. Buna ek olarak d parametresinin ayrıca kestirimi (Granger ve Joyeux, 1980; Hosking, 1981) ve kırılma sayısının bu kalibrasyona göre yorumlanması gerekir.
- **Confounders:** Mevsimsellik, kampanya dönemleri, uygulama sürüm geçişleri, altyapı bakım pencereleri.
- **Yanlış Pozitif Kaynakları:** Yeni hizmet devreye alma, bulut göçü, politika değişiklikleri.
- **Gerekli Baseline:** En az iki çeyrek dönem; kırılma sayısının baseline dağılımı.
- **Validasyon:** Bilinen değişiklik kayıtları (change management) ile kırılma noktalarının karşılaştırılması.
- **Kanıt Gücü:** Tek başına (bağlam zenginleştirme ile).

6.6 T6 — Uç Nokta Nedensellik Korelasyonu (ETW / eBPF)

- **Yüzey:** Uç nokta + ağ.

- **Veri Kaynağı:** Windows: süreç/iş parçacığı/görüntü olayları ve çekirdek ağ olayları (sağlayıcı seçimi, ad doğrulaması ve karıştırılmaması gereken adlar için Bölüm 7.1 notları). Linux: tracepoint ve kprobe tabanlı süreç/soket olayları.
- **Hipotez:** Belirli bir akışı üreten sürecin kimliği ve başlangıç bağlamı, akışın istatistiksel profiliyle ilişkilendirildiğinde açıklanamayan kombinasyonlar ortaya çıkar.
- **Gerekçe:** Trafik profilinin istatistiksel özellikleri ile süreç/oturum bağlamı **iki bağımsız boyuttur**. Bu boyutların birleştirilmesi, tek boyutlu analizin ürettiği belirsizliği azaltır.
- **Confounders:** PID yeniden kullanımı, süreç yeniden başlatma, konteyner/namespace katmanları, telemetri toplama gecikmesi, saat kayması, Windows'ta sağlayıcı sürüm farkları.
- **Yanlış Pozitif Kaynakları:** Toplu güncelleme ajanları, tarayıcı arka plan süreçleri, senkronizasyon istemcileri, konteyner içi yardımcı süreçler.
- **Gerekli Baseline:** Süreç envanteri ve normal ağ kullanım profili; süreç-ağ eşleştirmesinin sağlık metrikleri.
- **Validasyon:** Korelasyon anahtarının doğruluğunun bilinen bir test süreci ile doğrulanması; PID yeniden kullanımı senaryosunun sentetik olarak üretilmesi.
- **Kanıt Gücü:** Korelasyon altyapısı. Bu taktik tek başına tehdit kanıtı üretmez; akış ölçümlerinin süreç bağlamıyla eşleştirilmesini sağlayan bir altyapıdır. Eşleşmenin kendisi bir bulgu değildir; bulgu, eşleşen bağlamın diğer taktiklerle birlikte değerlendirilmesiyle üretilir.

6.7 T7 — Oturum ve Yetki Bağlamı Doğrulaması

- **Yüzey:** Uç nokta + kimlik.
- **Veri Kaynağı:** Oturum kimliği, masaüstü bağlılığı, token özellikleri, ebeveyn süreç zinciri, servis/görev yapılandırması.
- **Hipotez:** Servis veya etkileşimsiz (non-interactive) dağıtım modelinde, ağ kullanımı ile oturum bağlamı arasındaki uyumsuzluk yüksek değerli bir korelasyon sinyalidir. Bu sinyal, kullanıcı oturumu içinde çalışan süreçlerde **bulunmayabilir**; bu nedenle tek başına bir suçlama gerekçesi değildir.
- **Gerekçe:** Oturum ve yetki bağlamı, süreç davranışına ilişkin bağımsız bir boyuttur; istatistiksel profil ile birleştirildiğinde belirsizliği azaltır.
- **Confounders:** Meşru servisler ve zamanlanmış görevler, yapılandırma yönetimi ajanları, RMM araçları, uzaktan destek oturumları.
- **Yanlış Pozitif Kaynakları:** Kurumsal yönetim ajanları, yedekleme servisleri, CI/CD ajanları.
- **Gerekli Baseline:** Süreç-servis envanteri; hangi hizmetlerin hangi oturum bağlamında çalıştığının kaydı.
- **Validasyon:** Envanter tabanlı hariç tutma listelerinin oluşturulması ve periyodik yenilenmesi.
- **Kanıt Gücü:** Korelasyon gerektirir.

6.8 T8 — Girdi Olayı ve Ağ Aktivitesi Korelasyonu

- **Yüzey:** Uç nokta.
- **Veri Kaynağı:** Girdi olayı telemetrisi (HID), pencere odak değişimleri, oturum etkileşim olayları ve ağ aktivitesi.
- **Hipotez:** İş istasyonu sınıfında, ağ aktivitesi ile kullanıcı etkileşimi arasındaki korelasyon beklenen aralığın dışına çıkabilir.
- **Gerekçe:** Bu ilişki **olasılıksaldır**, zorunlu değildir. Tarayıcı arka plan etkinliği, otomatik kaydetme, dosya senkronizasyonu, medya akışı, service worker'lar, arka plan güncellemeleri ve meşru ajanlar kullanıcı girdisi olmadan ağ trafiği üretir. Bu nedenle ölçüm, kanıt değil; iş istasyonu sınıfına özgü bir olasılıksal özellik olarak ele alınır.
- **Confounders:** Kiosk ve sunucu sınıfı cihazlar, uzaktan oturumlar, sanal masaüstü altyapısı, otomasyon hesapları, terminal sunucuları.
- **Yanlış Pozitif Kaynakları:** Yukarıdaki meşru arka plan etkinliklerinin tamamı; ayrıca telemetri toplama aralığı ve örnekleme kaybı.
- **Gerekli Baseline:** Cihaz sınıfı bazında ağ/girdi korelasyon dağılımı; zaman bölmesi genişliğine duyarlılık analizi.
- **Validasyon:** Bilinen arka plan etkinliği senaryolarının (senkronizasyon, medya, güncelleme) ölçümü ve bunların dağılımdaki yerinin belirlenmesi.
- **Kanıt Gücü:** Korelasyon gerektirir.

6.9 T9 — Zamanlayıcı ve Uyku Deseni Telemetrisi

- **Yüzey:** Uç nokta.
- **Veri Kaynağı:** Zamanlayıcı API çağrıları ve uyku süreleri; süreç CPU zamanı dağılımı (kuruma özgü uç nokta telemetrisi).
- **Hipotez:** Bir sürecin uyku süreleri ile CPU zamanı dağılımı, çalıştığı iş yükü sınıfının baseline'ından sapabilir.
- **Gerekçe:** Zamanlayıcı tabanlı çalışma, ölçülebilir bir desen bırakır. Ancak bu desen yalnızca **iş yüküne özgü baseline** ile anlamlıdır: meşru servisler de ağır kuyruklu veya çok modlu uyku dağılımları üretebilir. Yeniden deneme ve geri çekilme (retry/backoff) politikaları, kuyruk güdümlü iş yükleri, rastgelelenmiş yoklama aralıkları ve bulut SDK'larının bekleme davranışları bunun yaygın örnekleridir.
- **Confounders:** Yukarıdaki meşru desenler; CPU ölçüm çözünürlüğü; sanal makine zamanlama sapması; güç yönetimi politikaları; süreç havuzu (pool) yeniden kullanımı.
- **Yanlış Pozitif Kaynakları:** Sağlık kontrol servisleri, kuyruk tüketicileri, oturum yenileme döngüleri, telemetri toplayıcıları.
- **Gerekli Baseline:** Süreç/uygulama bazında uyku ve CPU dağılımları; en az bir sürüm döngüsü boyunca.
- **Validasyon:** Bilinen meşru servislerin dağılımlarının ölçülmesi ve aday süreçlerin bu dağılımlara göre konumlandırılması.
- **Kanıt Gücü:** Korelasyon gerektirir.

6.10 T10 — TLS ve Uygulama Katmanı Tutarlılığı

- **Yüzey:** Ağ.
- **Veri Kaynağı:** Pasif TLS analizi (istemci parmak izi, kayıt boyları), uygulama düzeyi akış davranışı.
- **Hipotez:** İddia edilen uygulama ile gözlemlenen istemci davranışı arasında tutarsızlık bulunabilir.
- **Gerekçe:** Zamanlama profili ile istemci yığını bağımsız boyutlardır; istemci yığını taklidi, zamanlama taklidinden farklı bir mühendislik yükü doğurur.
- **Confounders:** Kurumsal proxy'ler ve TLS sonlandırma, uygulama sürüm güncellemeleri, tarayıcı sürüm çeşitliliği, ortak TLS kütüphaneleri, CDN davranışı.
- **Yanlış Pozitif Kaynakları:** Eski istemci sürümleri, gömülü cihazlar, üçüncü taraf entegrasyonlar.
- **Gerekli Baseline:** Uygulama başına JA4/JA3 ve kayıt boyu profili; sürüm bazlı dağılım.
- **Validasyon:** Bilinen uygulama envanteriyle eşleştirme; parmak izi kütüphanesinin periyodik güncellenmesi.
- **Kanıt Gücü:** Korelasyon gerektirir.

6.11 T11 — Paket Boyu Dağılımı ve Hacim Kümeleme

- **Yüzey:** Ağ.
- **Veri Kaynağı:** Paket düzeyi boyut verisi; akış bazında boyut histogramları.
- **Hipotez:** Baseline'da çok modlu olan bir iş yükü sınıfı içinde tek modlu bir alt küme, aday sapma göstergesidir.
- **Gerekçe:** Uygulama trafiğinin paket boyu dağılımı, protokol ve tampon politikalarına bağlı olarak çok modlu yapı sergiler. Tek modluluk bu nedenle bir aday özelliktir; zorunlu bir imza değildir.
- **Confounders:** Sıkıştırma, şifreleme dolgusu (padding), MTU/offload, protokol sürümü, uygulama tampon boyutu.
- **Yanlış Pozitif Kaynakları:** Tek tip iş yükleri (toplu veri aktarımı, IoT telemetrisi), düşük hacimli oturumlar.
- **Gerekli Baseline:** Uygulama sınıfı başına paket boyu histogramı ve mod yapısı.
- **Validasyon:** Bilinen uygulama örnekleriyle mod yapısının doğrulanması; düşük örneklemli akışların dışlanması.
- **Kanıt Gücü:** Korelasyon gerektirir.

6.12 T12 — Çapraz Katman Korelasyon Mimarisi

- **Yüzey:** Ağ + uç nokta + kimlik.
- **Veri Kaynağı:** Üç düzlemin ortak anahtar etrafında birleştirilmesi: (host_id, pid, process_start_time, five_tuple, event_time).
- **Hipotez:** Tek düzlemde belirsiz kalan bir gözlem, ikinci ve üçüncü düzlemle birleştirildiğinde triyaj edilebilir hale gelir.

- **Gerekçe:** İstatistiksel profil, süreç bağlamı ve kimlik bağlamı bağımsız boyutlardır; birleştirme bilgi kazancı sağlar. PID tek başına anahtar değildir; PID yeniden kullanımı yanlış eşleme üretir, bu nedenle süreç oluşturulma zamanı bileşeni zorunludur.
- **Confounders:** Saat kayması, telemetri toplama gecikmesi, eksik beşli demet, NAT/PAT dönüşümleri, konteyner katmanı.
- **Yanlış Pozitif Kaynakları:** Eksik veya gecikmeli telemetri nedeniyle oluşan hayalet eşleşmeler.
- **Gerekli Baseline:** Telemetri sağlık metrikleri (kapsama oranı, gecikme, kayıp oranı) ve eşleşme başarı oranı.
- **Validasyon:** Bilinen bir test akışı üzerinden uçtan uca eşleşme testi; PID yeniden kullanım senaryosu.
- **Kanıt Gücü:** Korelasyon altyapısı. Mimari, kendisi tehdit kanıtı üretmez; diğer taktiklerin (T1–T11, T13, T14) kanıt değerini yükseltir. Anahtar bütünlüğü doğrulanmadan üretilen eşleşmeler bulgu olarak raporlanmaz.

6.13 T13 — Aldatma ve Kanarya Akışlar

- **Yüzey:** Ağ.
- **Veri Kaynağı:** Kurum tarafından yayınlanan kontrollü profil ve kanarya hedefleri; bunlara yönelik etkileşim kayıtları.
- **Hipotez:** Yalnızca aldatma amacıyla yayınlanan profillere veya hedeflere yönelik etkileşim, meşru kullanıcı davranışıyla açıklanamaz.
- **Gerekçe:** Bu taktik bir **tehdit modeli varsayımına** dayanır: karşı tarafın, gözlemlediği trafik profilini taklit etmeye çalıştığı varsayılır. Varsayım geçerli değilse taktik değer üretmez; bu nedenle sonuçlar varsayıma bağlı olarak raporlanır.
- **Confounders:** Envanter hataları, yanlış yapılandırılmış istemciler, güvenlik tarayıcıları, araştırma amaçlı iç trafik.
- **Yanlış Pozitif Kaynakları:** Yanlış pozitif maliyeti düşüktür; ancak envanter kirliliği alarm yorgunluğu üretebilir.
- **Gerekli Baseline:** Kanarya varlıklarının envanteri ve erişim politikası; düzenli doğrulama.
- **Validasyon:** Kanarya bileşenlerinin düzenli olarak test edilmesi ve üretilen alarmların gözden geçirilmesi.
- **Kanıt Gücü:** Tek başına.

6.14 T14 — Uzun Ufuklu İzleme ve Mevsimsellik

- **Yüzey:** Ağ.
- **Veri Kaynağı:** 90–365 gün arşivlenmiş akış özetleri; mevsimsel bileşen analizi.
- **Hipotez:** Mevsimsel yapı (çeyrek sonu yoğunluğu, izin dönemleri, tatil haftaları) yalnızca uzun ufukta görünür hale gelir; bu yapıya uymayan profiller aday sapmadır.
- **Gerekçe:** Uzun ufuk, kestiricinin varyansını düşürür ve mevsimsel bileşeni ayırıştırır. Bu bir istatistiksel kazançtır; **evrensel bir süre sınırı değildir**.
- **Confounders:** Kurumsal değişimler, yeni hizmetler, personel hareketleri, altyapı göçleri.
- **Yanlış Pozitif Kaynakları:** Mevsimsel ama düzensiz iş yükleri, proje bazlı faaliyetler.
- **Gerekli Baseline:** Yıllık döngüyü kapsayan en az bir tam periyot; mevsimsel ayırıştırma modeli.
- **Validasyon:** Baseline'ın bir bölümünün dışarıda bırakılması (hold-out) ve modelin öngörü performansının ölçülmesi.
- **Kanıt Gücü:** Korelasyon gerektirir.

6.15 T15 — Savunma Profili Simülatörü ile Dedektör Validasyonu

- **Yüzey:** Tümü.
- **Veri Kaynağı:** Kurum tarafından kontrol edilen, izole segmentte çalışan **savunma profili simülatörü** ve üretim dedektörlerinin çıktıları.
- **Hipotez:** Dedektörlerin tespit ve yanlış pozitif davranışı, bilinen istatistiksel özelliklere sahip kontrollü trafik ile ölçülebilir.
- **Gerekçe:** Doğrulanmamış dedektörün üretim davranışı bilinmez. Kurum kontrollü bir simülatör, meşru-benzeri (benign-like) sentetik trafik üretir; bu, gerçek bir saldırı aracı değildir ve hedef sistemlere yönelik değildir. Amaç, dedektörün yanıt eğrisini, eşik duyarlılığını ve yanlış pozitif oranını ölçmektir.
- **Confounders:** Simülatörün kendi üretim artefaktları (uygulama katmanı tutarsızlıkları), izole segmentin baseline'dan farkı, ölçek farkı.

- **Yanlış Pozitif Kaynakları:** Simülatörün ürettiği trafiğin meşru segmentlere sızması (segmentasyon hatası).
- **Gerekli Baseline:** Hem meşru segment baseline'ı hem simülatörün kendi ölçülen profili.
- **Validasyon:** Dedektör yanıt eğrisinin ölçülmesi; marjinal katkı analizi (Bölüm 8.3); sonuçların yazılı olarak kaydedilmesi.

6.16 T16 — Depolama Alt Sistem Doğrudan Geçiş Denetimi

- **Yüzey:** Uç Nokta (Depolama / Blok G/Ç Katmanı).
- **Veri Kaynağı:** Windows: Microsoft-Windows-StorPort ETW sağlayıcısı (EventID 500-502), DeviceEvents (DeviceIoControl). Linux: eBPF tracepoint/syscalls/sys_enter_ioctl (SG_IO 0x2285), tracepoint/block/block_rq_issue.
- **Hipotez:** Standart depolama yönetim süreçleri haricindeki kullanıcı modu ikililerinin doğrudan fiziksel disklere (\\.\PhysicalDrive*, /dev/sd*) SCSI komut blokları (CDB Opcode 0x1D - SEND_DIAGNOSTIC veya 0xC0-0xFF aralığındaki üreticiye özel opcode'lar) göndermesi, bant-dışı (OOB) gizli tünelleme girişimini gösterir.
- **Gerekçe:** Standart ağ telemetri katmanları (WFP, NDIS, eBPF TC) blok depolama katmanını izlemez. Depolama tanılama geçişleri ağ sensörlerini tamamen kör bırakır.
- **Karıştırıcılar:** RAID/NVMe yönetim araçları (StorCLI, MegaRAID, Intel RST), disk SMART izleme servisleri (smartctl).
- **Yanlış Pozitif Kaynakları:** Donanım üreticisi tanılayıcıları, ham snapshot tabanlı kurumsal yedekleme ajanları.
- **Gerekli Temel Hat:** Ham blok aygıtlara erişim yetkisi onaylanmış kurumsal ikili envanteri.
- **Doğrulama:** Kontrollü IOCTL SCSI_PASS_THROUGH_DIRECT tanılama çerçeveleri enjeksiyonu.
- **Kanıt Gücü:** Tek Başına Güçlü (Yüksek Öncelikli Triyaj).

6.17 T17 — IOMMU / DMA Tutarlı Tampon & Halka Tanımlayıcı Denetimi

- **Yüzey:** Donanım / Çekirdek (Veri Yolu Katmanı).
- **Veri Kaynağı:** Çekirdek DMA Koruması (DMAR) denetim günlükleri, hipervizör IOMMU sayfa hataları, çekirdek tampon tahsis telemetrisi (dma_alloc_coherent, AllocateCommonBuffer).
- **Hipotez:** Kayıtsız veya ağ dışı PCIe uç noktalarının ana bellek (DRAM) üzerinde yüksek frekanslı dairesel halka tamponlar tahsis etmesi ve MMIO kapı zili (doorbell) tetiklemesi, donanım tabanlı bir gizli köprüyü (SmartNIC, FPGA) işaret eder.
- **Gerekçe:** Kurumsal DMA kanalları IOMMU tarafından izole edilir. Standart hesaplama iş yükleri ile sürekli iletişim halkaları arasında tampon tahsis deseni farkı oluşur.
- **Karıştırıcılar:** Yüksek başarılı GPU hesaplamaları (CUDA/OpenCL), yüksek verimli NVMe kuyruk yönetimi.
- **Yanlış Pozitif Kaynakları:** Makine öğrenimi hızlandırıcı kartları, yüksek hızlı kare yakalayıcılar.
- **Gerekli Temel Hat:** Kurumsal PCIe donanım envanteri (Vendor/Device ID) ve IOMMU eşleme profilleri.
- **Doğrulama:** Test PCIe uç noktaları üzerinden simüle edilmiş halka tampon tahsisi.
- **Kanıt Gücü:** Korelasyon Gerektilir.

6.18 T18 — Donanım Performans Sayacı (PMU) & Bellek Bariyeri Frekansı

- **Yüzey:** Donanım / CPU Mikro Mimarisi.
- **Veri Kaynağı:** Donanımsal Performans İzleme Birimleri (Linux'ta perf_event_open, Windows'ta ETW PMU olayları).
- **Hipotez:** Bir sürecin normal uygulama modellerine aykırı biçimde aşırı sıklıkta bellek serileştirme bariyeri (SFENCE, LFENCE, MFENCE) yürütmesi ve eşzamanlı olarak MMIO bellekle eşlenmiş bölgelere yazması.
- **Gerekçe:** Donanım DMA halkalarına tutarlı veri yazmak, kapı zili çalınmadan önce CPU depolama bariyerlerinin zorlanmasını gerektirir.
- **Karıştırıcılar:** Yüksek Frekanslı Alım-Satım (HFT) algoritmaları, kilit-içermeyen (lock-free) çoklu iş parçacığı kütüphaneleri, grafik işleme motorları.
- **Yanlış Pozitif Kaynakları:** Atomik operasyonlar kullanan yüksek performanslı eşzamanlı çalışma zamanları.
- **Gerekli Temel Hat:** Süreç sınıflarına göre PMU komut dağılımı ve bellek bariyeri referans çizgileri.
- **Doğrulama:** Referans kilit-içermeyen algoritmalarla mikro-mimari karşılaştırma.
- **Kanıt Gücü:** Aday Özellik (Korelasyon Gerektilir).

6.19 T19 — İnsan Varlığı & HID Etkileşim Nedensellik Korelasyonu

- **Yüzey:** Uç Nokta + Ağ (Çapraz Katman Nedenselliği).
- **Veri Kaynağı:** Windows: GetLastInputInfo, WM_INPUT, oturum kilit durumu olayları. Linux: /dev/input/*, evdev olayları, oturum boşta sayaçları. Ağ: Çıkış NetFlow / soket bayt sayaçları.
- **Hipotez:** Etkileşimli kullanıcı oturumunda (Oturum 1+) çalışan ve uzun süreli kullanıcı hareketsizliği (boşta kalma > 60s) veya masaüstü kilitliyen periyodik ya da patlamalı dış ağ trafiği üreten süreçler şüpheli otomasyon ajanlarıdır.
- **Gerekçe:** Gerçek kullanıcı uygulamaları insan giriş aktivitesine nedensel olarak bağımlıdır ($P(\text{Çıkış}_t > 0 \mid \text{son HID aktivitesi}) \neq P(\text{Çıkış}_t > 0 \mid \text{boşta/kilitli durum})$). Otomatize ajanlar fiziksel klavye/fare girdileriyle zamansal bağa sahip değildir.
- **Karşıtıncılar:** Tarayıcı sekmelerinin arka planda otomatik yenilenmesi, aktif arka plan ses/video akışları.
- **Yanlış Pozitif Kaynakları:** Kullanıcı kilitlediğinde tetiklenen kurumsal arka plan yedekleme veya imza güncelleme görevleri.
- **Gerekli Temel Hat:** Aygıt türü sınıflandırması (İş İstasyonu vs. Sunucu) ve uygulama sınıfı HID korelasyon matrisleri.
- **Doğrulama:** Doğrulanmış boşta ve kilitli aralıklarda ağ çıkış davranışının profillenmesi.
- **Kanıt Gücü:** Yüksek Korelasyon Gücü.

6.20 T20 — Alt Sistem TLS Yığını Sapması & ETW WinHTTP/Schannel Doğrulaması

- **Yüzey:** Uç Nokta (Modül Yükleme) + Ağ (TLS El Sıkışması).
- **Veri Kaynağı:** Windows: Microsoft-Windows-Kernel-Process (ImageLoad), Microsoft-Windows-WinHttp ETW sağlayıcısı, Sanal Adres Tanımlayıcıları (VAD). Ağ: 443 TCP akışları ve pasif JA4 parmak izleri.
- **Hipotez:** Dışarıya 443 TCP bağlantısı kuran ancak modül listesinde işletim sistemi HTTP/TLS kütüphaneleri (winhttp.dll, schannel.dll) bulunmayan ve sıfır Microsoft-Windows-WinHttp ETW olayı üreten süreçler bağımsız veya gömülü kriptografik motorları işaret eder.
- **Gerekçe:** Meşru kurumsal masaüstü uygulamaları işletim sistemi HTTP/TLS yığını kullanarak kurumsal proxy, sertifika zinciri ve merkezi denetim günlüğü mirasını devralır. Ayrı TLS kütüphaneleri JA4 uyumsuzluğu ve modül yokluğu oluşturur.
- **Karşıtıncılar:** Statik TLS kütüphaneleriyle derlenmiş geliştirici araçları (Go, Rust, Python, Node.js, curl).
- **Yanlış Pozitif Kaynakları:** Dahili BoringSSL motoru kullanan Electron tabanlı kurumsal uygulamalar (Slack, Teams).
- **Gerekli Temel Hat:** Statik/gömülü TLS motoru kullanan kurumsal onaylı ikili envanteri.
- **Doğrulama:** ETW modül yüklemeleri ile giden soket bağlantılarının çapraz denetimi.
- **Kanıt Gücü:** Korelasyon Gerektirir (T6 ve T10'u tamamlar).

7. Tespit Mühendisliği Çıktıları

7.1 Telemetri Gereksinim Matrisi ve Sağlayıcı Notları

Telemetri	Kaynak / sağlayıcı	Taktikler	Zaman damgası birimi	Öncelik
Akış kayıtları	IPFIX/NetFlow, bağlantı kayıtları	T1, T2, T4, T5, T14	saniye (tipik akış granülaritesi)	Kritik
Paket düzeyi zaman damgaları	TAP/SPAN + paket sensörü (bağlantı kaydı yetersiz)	T3, T11	sensöre bağlı (mikrosaniye mertebesi tipik)	Yüksek
Süreç, iş parçacığı, görüntü olayları	Windows çekirdek ETW sağlayıcıları (Threat-Intelligence ve genel süreç sağlayıcıları)	T6, T7	ETW zaman damgası birimi 100 ns	Kritik
PID→akış eşlemesi	Çekirdek ağ ETW sağlayıcısı	T6, T12	olay bazlı	Kritik

Telemetri	Kaynak / sağlayıcı	Taktikler	Zaman damgası birimi	Öncelik
Linux süreç/soket olayları	tracepoint + kprobe (eBPF)	T6, T7, T9	çekirdek saat birimi (ns)	Kritik
Girdi olayı telemetrisi	Uç nokta ajanı (WM_INPUT, /dev/input)	T8, T19	ms (ajan toplama aralığı)	Kritik
TLS parmak izi	Pasif TLS analizi (JA4/JA3)	T10, T20	oturum bazlı	Yüksek
Depolama Geçiş G/Ç	Windows StorPort ETW / Linux eBPF SG_IO	T16	olay bazlı	Kritik
Çekirdek DMA / IOMMU Günlükleri	DMAR Denetim Günlükleri / IOMMU Sayfa Hataları	T17	olay bazlı	Yüksek
Donanım Performans Sayaçları	Donanım PMU / perf_event_open	T18	olay bazlı	Orta
WinHTTP / Schannel Çağrılar	Windows ETW (Microsoft-Windows-WinHttp)	T20	olay bazlı	Yüksek
Kimlik ve oturum bağlamı	Dizin / SIEM / uç nokta zenginleştirme	T7, T12	olay bazlı	Yüksek

Çözünürlük uyarısı. Bu sütundaki değerler **zaman damgası birimi veya nominal granüleritedir; efektif ölçüm çözünürlüğü değildir.** Gerçek çözünürlük; saat kaynağına (TSC, HPET, donanım zaman damgası), sağlayıcının ve çekirdeğin damga üretim yoluna, platforma ve sanallaştırma katmanına bağlıdır. Örnek: 100 ns'lik bir damga birimi, olayların 100 ns çözünürlükle ölçüldüğü anlamına gelmez; toplama gecikmesi, kuyruk gecikmesi ve saat disiplini (NTP/PTP) etkin çözünürlüğü belirler. Zamanlama tabanlı ölçümler (T3, T9, T18) kurulmadan önce etkin çözünürlük hedef ortamda deneysel olarak ölçülmelidir.

Sağlayıcı notları. Bu matris bir referans mimarinin seçimidir; tek olası kaynak kümesi değildir.

- Çekirdek ağ olayları için bu raporda referans alınan sağlayıcı, PID ve uç nokta çifti taşıyan çekirdek ETW ağ sağlayıcısıdır. Aynı bilgi farklı sağlayıcı, sürücü veya platform mekanizmalarından da elde edilebilir; seçim kurumun telemetri yığına bağlıdır.
- Sağlayıcı adı ile olay/kategori adları karıştırılmamalıdır.** Windows sürümleri arasında olay kimlikleri, anahtar sözcükler (keyword) ve kategori adları değişebilir. Her sağlayıcı için hangi olay ve anahtar sözcüklerin hangi Windows derlemesinde mevcut olduğu, hedef ortamda sağlayıcı manifestosundan doğrulanmalıdır (wevtutil gp, logman query providers).
- Korumalı çekirdek telemetri sağlayıcıları yalnızca belirli tüketici sınıflarına açıktır ve ağ demeti sağlamaz; ağ eşlemesi ayrı sağlayıcıdan gelir. İki kaynağın ortak anahtarı (PID, süreç oluşturulma zamanı) çiftidir.
- Telemetri kaynağı seçilirken güven düzeyi ile kapsam birlikte değerlendirilir; hiçbir sağlayıcı tek başına tam kapsam sağlamaz.

7.2 Süreç Bağlamı Kuralı (Sigma, referans)

Aşağıdaki kural, standart process_creation logsource'u üzerinde çalışır ve başlığı yaptığı işi tanımlar. Oturum kimliği kontrolü bu kuralın kapsamında değildir; Session 0 veya benzeri bir bağlam kontrolü ayrı bir zenginleştirme/korelasyon katmanına bırakılmıştır.

```

title: Hidden or Non-Interactive Script Host Launched by Scheduler
id: 8f3c1a72-4d5e-4a91-9a1e-7c2b6d0e5f31
status: experimental
logsource:
  category: process_creation
  product: windows
detection:
  selection_parent:
    ParentImage|endswith:
      - '\svchost.exe'

```

```

- '\taskeng.exe'
- '\schtasks.exe'
selection_child:
  Image|endswith:
    - '\powershell.exe'
    - '\pwsh.exe'
    - '\wscript.exe'
    - '\python.exe'
selection_flags:
  CommandLine|contains:
    - '-WindowStyle Hidden'
    - '-NonInteractive'
    - '-EncodedCommand'
condition: selection_parent and selection_child and selection_flags
fields:
- Computer
- User
- ParentImage
- Image
- CommandLine
falsepositives:
- Yönetim ve RMM ajanları
- Yapılandırma yönetimi (SCCM/Intune) görevleri
level: medium

```

Uygulama notları:

- Standart process_creation logsource'unda bulunmayan alanlar (örneğin oturum kimliği) bu kurala eklenmez. Kurum bu alanı kendi zenginleştirme hattında sağlıyorsa, alanın kaynağı ve doldurulma oranı belgelenmeli ve kural kuruma özgü bir Sigma pipeline'ı ile eşlenmelidir.
- Kural tek başına C2 tespiti değildir; bağlam zenginleştirilmesi (oturum bağlamı, akış ölçümleri) ayrı katmanda yapılır.

7.3 Ölçekleme ve Bağlam Korelasyonu (KQL, referans)

Aşağıdaki sorgu **referans/pseudocode KQL** olarak sunulmuştur: ölçüm tablosu ve zenginleştirilmiş uç nokta tablosu kuruma özgüdür ve bu şemalarla bire bir çalışacağı garanti edilmez.

Ölçüm tablosu şeması (veri gölü işi tarafından doldurulur):

```

TrafficScalingMetrics_CL
TimeGenerated : datetime
DeviceId      : string
WindowHours   : int
HurstWavelet  : real      // dalgacık tabanlı kestirim
HillAlpha     : real      // kuyruk indeksi
PsdSlope     : real      // log-log eğim
SampleCount   : int

```

Zenginleştirilmiş uç nokta tablosu şeması (alan kaynağı belirtilmiştir):

```

EndpointContext_CL
TimeGenerated : datetime // olay zamanı (uç nokta ajanı)
DeviceId      : string    // envanter kimliği
ProcessId     : int       // süreç kimliği
ProcessStartTime : datetime // PID yeniden kullanımını ayırt etmek için zorunlu
SessionId     : int       // oturum bağlamı (kaynak: uç nokta zenginleştirilmesi)
IsInteractive  : bool      // masaüstü bağlantılığı / oturum türü

```

```

// Referans KQL – şema ve alan adları kuruma göre uyarlanmalıdır.
let lookback = 30d;
let scaling = TrafficScalingMetrics_CL
| where TimeGenerated > ago(lookback) and SampleCount > 50
| summarize H_avg = avg(HurstWavelet), H_std = stdev(HurstWavelet), Samples = sum(SampleCount) by DeviceId
// H_avg aralığı örnek bir değerdir; kurum baseline'ından türetilmelidir (bkz. Bölüm 8.1).
| where Samples > 2000 and H_avg between (0.55 .. 0.90) and H_std < 0.05;
let context = EndpointContext_CL
| where TimeGenerated > ago(lookback) and IsInteractive == false
| summarize HeadlessCount = dcount(ProcessId), Examples = make_set(SessionId, 5)
  by DeviceId, ProcessId, ProcessStartTime;
scaling
| join kind=inner context on DeviceId

```

```
| project DeviceId, H_avg, H_std, Samples, HeadlessCount, ProcessStartTime
| order by H_std asc
```

Notlar: SessionId ve IsInteractive alanları u  nokta zenginleřtirmesinden gelir; standart s re  olaylarında hazır bulunmaları varsayılmamalıdır. S re  d zeyinde birleřtirme yapılacaksa (DeviceId, ProcessId, ProcessStartTime)   l s  kullanılır.

7.4 Kuantizasyon Aday  zelliĐi Testi (paket d zeyi)

Bu test paket d zeyi zaman damgası gerektirir. BaĐlantı kayıtları (conn.log, NetFlow) bu ama la kullanılamaz: bu kayıtlar baĐlantı bařlangı /bitiř damgaları tařır, paketler arası s re saĐlamaz. Gerekli kaynak, (flow_id, ts, pkt_len)  reten bir paket sens r d r.

```
index=sensor sourcetype="c2sensor:packet"
| sort 0 + _time
| streamstats current=f last(_time) as prev_ts by flow_id
| eval iat_ms = round((_time - prev_ts) * 1000, 3)
| where isnotnull(iat_ms) AND iat_ms > 0
| eval phase = iat_ms % q
| eval edge = min(phase, q - phase)
| stats count as total, sum(eval(if(edge < tau, 1, 0))) as edge_hits by src_ip, dest_ip
| eval edge_share = round(edge_hits / total, 4)
| where total > 500 AND edge_share > theta_edge
| table src_ip, dest_ip, total, edge_share
```

Kuantizasyon birimi (q), faz toleransı ( ), edge_share eřiĐi ( _edge) ve ki-kare eřiĐi ( _chi2) burada **sabit deĐer olarak verilmemiřtir**; her biri kurum, host ve derleme baseline'ından t retilmeli ve yanlılık/varyans analiziyle doĐrulanmalıdır. Bu parametreler segmentten segmente deĐiřir; evrensel bir deĐer varsayılmamalıdır.

```
import numpy as np

# q, tau, theta_edge, theta_chi2: kurum/host/derleme baseline'ından t retilen
# parametrelerdir; sabit kabul edilmemelidir.

def quantum_comb_score(ts_ns: np.ndarray, q_ms: float, tau_ms: float,
                       theta_edge: float, theta_chi2: float) -> dict:
    """Zaman damgası dizisinde (ns) kuantizasyon yigirma desenini  lcer.
    Donen deger bir aday ozelliktir; tek basina kanit degildir."""
    ts = np.sort(np.asarray(ts_ns, dtype=np.int64))
    iat_ms = np.diff(ts) / 1e6
    iat_ms = iat_ms[iat_ms > 0]
    if iat_ms.size < 500:
        return {"n": int(iat_ms.size), "verdict": "insufficient_sample"}

    phase = np.mod(iat_ms, q_ms)
    edge = np.minimum(phase, q_ms - phase)
    edge_share = float(np.mean(edge < tau_ms))

    counts, _ = np.histogram(phase, bins=16, range=(0.0, q_ms))
    expected = counts.sum() / 16.0
    chi2 = float(np.sum((counts - expected) ** 2 / expected))

    return {
        "n": int(iat_ms.size),
        "edge_share": round(edge_share, 4),
        "chi2": round(chi2, 2),
        "verdict": "candidate" if edge_share > theta_edge and chi2 > theta_chi2 else "inconclusive",
    }
```

Faz daĐılımı d zg n olduĐunda edge_share deĐerinin $2 /q$ mertebesinde kalması beklenir; bu referans deĐer kuantizasyon birimine ve toleransa baĐlıdır ve segment baseline'ından hesaplanmalıdır. Referans deĐer ayrıca sens r n zaman damgası kaynaĐına, saat disiplinine ve aĐ katmanındaki gecikme daĐılımına g re deĐiřir (B l m 6.3 confounders listesi).

7.5 S re  BaĐlamı  l m  (eBPF / bpftrace)

```
/* bpftrace: 60 sn penceresinde surec basina gonderilen bayt
tcp_sendmsg(struct sock *sk, struct msghdr *msg, size_t size) -> arg2 = size */
```

```
kprobe:tcp_sendmsg
{
  @bytes[comm, pid] = sum(arg2);
}
interval:s:60
{
  print(@bytes);
  clear(@bytes);
}
```

Süreç bağlamının çekirdek içinde belirlenmesi için CO-RE yaklaşımı (BTF gerekir, çekirdek 5.8+):

```
/* libbpf CO-RE: kontrol eden terminali (controlling tty) olmayan görevler */
static __always_inline int has_controlling_tty(void)
{
  struct task_struct *task = (struct task_struct *)bpf_get_current_task_btf();
  struct signal_struct *sig = BPF_CORE_READ(task, signal);

  if (!sig)
    return 0;
  return BPF_CORE_READ(sig, tty) != NULL;
}
```

Notlar: signal_struct::tty alanının BTF'de bulunması gerekir; bulunmadığı çekirdeklerde /proc/<pid>/stat alan 7 (tty_nr) kullanıcı modunda controlling-TTY için alternatif göstergedir. getsid() yalnızca session ID sağlar; controlling TTY varlığını tek başına doğrulamaz. sendto/sendmsg kancalarında argüman sırası çağrıya göre değişir. Terminal yokluğu, tek başına kanıt değil; servis bağlamı için aday bir özelliktir.

7.6 Dedektör Yaşam Döngüsü

Her dedektör için sürümler, sahiplik ve ölçüm zorunludur: dedektör kimliği, sahibi, veri bağımlılığı (sağlayıcı/tablo ve alan kaynağı), tespit mantığı sürümü, bilinen yanlış pozitif kaynakları, kanıt gücü sınıfı ve son kalibrasyon tarihi. Kalibrasyon tarihi 90 günü aşan dedektörler üretimde "doğrulanmamış" olarak işaretlenir.

8. Yanlış Pozitif Yönetimi ve Ölçüm

8.1 Segmentasyon ve Nitel Baseline

Kurumsal ölçekte tek bir baseline yoktur; iş yükü profilleri yapısal olarak farklıdır. Önerilen segmentasyon nitel olarak tanımlanmıştır; her segment için sayısal eşik, o segmentin kendi ölçümünden türetilir.

Segment	Ölçekleme Davranışı	Diyurnal Profil	Not
Bilgi işçisi istasyonları	Güçlü LRD	Keskin mesai eğrisi	En yüksek öncelikli segment
Geliştirici makineleri	Orta-güçlü LRD	Gece aktivitesi dahil	Yüksek yanlış pozitif riski
Uygulama sunucuları	Güçlü LRD	Zayıf mesai bağımlılığı	Trafik sürekliliği yüksek
Yedekleme / toplu işler	Baskın patlama yapısı	Pencere tabanlı	Ayrı işlenmeli
Kiosk / üretim uçları	Zayıf-orta LRD	Dar mesai penceresi	Girdi telemetrisi sınırlı

Sayısal ölçekleme aralıkları (örneğin bir KQL sorgusunda H_avg için verilen bant) **kurum baseline'ından türetilmesi gereken örnek değerlerdir**; sektörel veya evrensel norm olarak sunulmamalıdır. Bir raporda sayısal aralık verilecekse, o aralığın hangi ölçümden, hangi segmentten ve hangi kestiriciden geldiği belirtilmelidir. Bu raporda sayısal ölçekleme aralığı bilinçli olarak verilmemiştir; yalnızca Bölüm 7.3'te örnek bir sorgu değeri olarak işaretlenmiştir.

8.2 Yanlış Pozitif Kaynakları

- **Yedekleme ve replikasyon:** Ağır kuyruklu ve periyodik; ölçekleme ölçümleri yüksek çıkar. Ayrı segment tanımı ile izole edilir.
- **CDN ve bulut erişimi:** Zamanlama profili istemci tarafından değil altyapı tarafından belirlenir; istemci tarafı istatistikleri anlamsızlaşır. Hedef bazlı hariç tutma uygulanır.

- **Uç nokta ve yönetim ajanları:** Sürekli, düşük hacimli ve kararlı; T1 ile T4 dedektörlerini doğrudan tetikler. Envanter ve sertifika tabanlı hariç tutma zorunludur.
- **CI/CD ve otomasyon:** İnsan taklidi yapmayan ancak yüksek hacimli trafik; kimlik ve süreç bağlamı ile ayrıştırılır.
- **VPN ve sanallaştırma:** Zaman damgası ve kuantizasyon ölçümlerini bozar; T3 yalnızca uç noktaya yakın segmentlerde uygulanır.
- **Tarayıcı ve işletim sistemi arka plan etkinliği:** Senkronizasyon, otomatik kaydetme, güncelleme ve medya akışı; T8 ölçümünün temel karıştırıcılarıdır.

8.3 Ölçüm Çerçevesi

- **Dedektör başına sinyal/gürültü oranı:** Haftalık alarm sayısı ve doğrulanmış tehdit oranı.
- **Taktik başına marjinal katkı:** Kontrollü simülasyon (T15) ile ölçülen ek tespit oranı.
- **Kapsam oranı:** Akış hacminin yüzde kaçının en az iki bağımsız dedektör tarafından değerlendirildiği.
- **MTTD:** Simülasyon senaryolarında ölçülen tespit süresi; üç aylık eğilim.
- **Yanlış pozitif maliyeti:** Analist saati cinsinden triyaj yükü.
- **Telemetri sağlığı:** Kapsama oranı, toplama gecikmesi, alan doldurulma oranı (özellikle zenginleştirilmiş alanlar için).

8.4 Pencere Uzunluğunun Belirlenmesi

Raporda geçen 30, 90 ve 180 günlük ufuklar **operasyonel başlangıç noktalarıdır**; evrensel matematiksel sınırlar değildir. Gerekli pencere uzunluğu şu etkenlere bağlıdır:

- **Örnekleme oranı:** Birim zamandaki gözlem sayısı; düşük hacimli akışlarda aynı istatistiksel güce ulaşmak için daha uzun pencere gerekir.
- **Durağanlık:** İş yükü pencere içinde durağan değilse, kestirim rejim karışımını yansıtır ve yanıltıcı olur.
- **Kestiricinin yanlılık/varyans davranışı:** Kısa pencerelerde yanlılık, uzun pencerelerde dışsal değişim riski baskın hale gelir.
- **Mevsimsel yapı:** Mevsimsel bileşeni ayırtmak için en az bir tam periyot gerekir.
- **Maliyet:** Saklama ve hesaplama maliyeti, pencere uzunluğuyla doğrusal olarak artar.

Bu nedenle pencere uzunluğu, segment bazında duyarlılık analizi ile belirlenmeli ve yazılı olarak gerektendirilmelidir.

8.5 Başsız Sunucu Paradoksu ve Alternatif Nedensellik Düzlemleri

İş istasyonu ortamlarında insan-fiziksel girdi etkileşimi (HID, fare/klavye olayları, oturum kilit durumu) ağ çıkışı için en güçlü nedensellik filtrelerinden biridir ($P(\text{Çıkış}_t > 0 \mid \text{son HID aktivitesi}) \neq P(\text{Çıkış}_t > 0 \mid \text{boşta/kilitli durum})$). Ancak kurumsal başsız sunucularda (headless Linux/Windows sunucular, arka plan veri tabanı düğümleri, konteyner worker'ları) fiziksel HID donanımı ve etkileşimli oturum bulunmaz.

Bu ortamda nedensellik korelasyonu şu alternatif çekirdek ve sistem düzlemlerine bağlanmalıdır:

- **Zamanlanmış İş / Cron Nedenselliği:** Ağ çıkışının cron, systemd.timer veya Windows Görev Zamanlayıcı olaylarıyla zamansal korelasyonu.
- **Gelen İstek Bağımlılığı (RPC / HTTP):** Sunucunun dışarıya başlattığı bağlantıların, içeriye gelen meşru bir kullanıcı veya API isteği tarafından tetiklenip tetiklenmediği (SO_ORIGINAL_DST, HTTP X-Request-ID).
- **İş Parçacığı Havuzu Aktivitesi:** Dinamik iş kuyrukları ve çekirdek epo11/IOCP olaylarının soket yazma operasyonlarıyla eşleşmesi.

8.6 Sürekli Poisson Zamanlayıcı Kalibrasyonu

Ayrıklaşmış zamanlayıcıların en büyük zaafı, işletim sistemi zamanlayıcı çözünürlüğüne veya tamsayı saniye/milisaniye sınırlarına yaslanarak frekans domeninde periyodik tarak deseni (comb filtering, T3) üretmesidir.

Savunma profili simülasyonunda ve zamanlama analizinde bu artefaktı engellemek için IEEE 754 64-bit sürekli rassal değişkenler üzerinden ters dönüşüm örnekleme zorunludur:

$$t_{\text{next}} = t_{\text{now}} - (1 / \lambda) * \ln(U) , \quad U \sim \text{Uniform}(0, 1)$$

Burada U sürekli bir kayan nokta olarak örneklenmeli, elde edilen aralık ayrık zaman adımlarına yuvarlanmadan yüksek çözünürlüklü nano-saniye zamanlayıcılar (CreateWaitableTimerExW yüksek çözünürlüklü bayrağı veya Linux clock_nanosleep CLOCK_MONOTONIC) üzerinden işletilmelidir. Bu sayede frekans uzayında Dirac atomları bütünüyle yok edilerek tam beyaz gürültü spektrumu elde edilir.

9. Olgunluk Modeli ve Yol Haritası

9.1 Olgunluk Seviyeleri

Seviye	Tanım	Karakteristik Yetenek
L1 — Reaktif	Gösterge (IOC) ve imza tabanlı	Statik göstergeler
L2 — Eşik Tabanlı	Volumetrik ve periyodiklik dedektörleri	Sabit eşikler, yüksek yanlış pozitif
L3 — İstatistiksel	Ölçekleme ve kuyruk ölçümleri; aday özellik yönetimi	T1, T2, T5
L4 — Nedensel	Akış-uç nokta-kimlik korelasyonu	T6, T7, T8, T12
L5 — Uyarlanabilir	Kontrollü simülasyon ile sürekli kalibrasyon	T13, T15, otomatik baseline yenileme

Kurumsal hedef, kritik segmentlerde L4'e, tamamında en az L3'e ulaşmaktır. L5 sürekli bir süreçtir; tek seferlik proje olarak ele alınmaz.

9.2 Yol Haritası

0–30 gün (temel): akış telemetrisinin pencere uzunluğu duyarlılık analiziyle birlikte kurulması; T1 ölçümünün devreye alınması; dedektör envanteri ve ölçüm çerçevesinin tanımlanması.

30–60 gün (korelasyon): süreç bağlamı telemetrisinin PID ve süreç başlangıç zamanı ile akışa bağlanması (T6, T12); oturum bağlamı doğrulamasının (T7) devreye alınması; paket düzeyi sensör kapsamının belirlenmesi ve T3 aday özelliğinin seçili segmentlerde başlatılması.

60–90 gün (doğrulama): kurum kontrollü savunma profili simülatörü ile dedektör validasyonu (T15); tespit ve yanlış pozitif ölçümü; aldatma katmanının (T13) pilot uygulaması.

90–365 gün (kurumsallaşma): uzun ufuklu mevsimsellik analizi (T14); dedektör yaşam döngüsü sürecinin resmileştirilmesi; olgunluk seviyesinin çeyreklik gözden geçirilmesi.

10. Savunma Borcu ve Sürekli Kalibrasyon

Tespit mimarisi, karşı tarafın uyum davranışına bağlı olarak değer kaybeder: bir tespit yüzeyi kapatıldığında gözlemlenebilir iz başka bir yüzeye kayar. Bu nedenle tespit kapasitesi bir proje çıktısı değil, sürdürülmesi gereken bir yetenektir. Bu rapor, karşı tarafın kaçınma adımlarını yöntem düzeyinde ele almaz (bkz. Bölüm 4); bunun yerine savunma tarafının yapışal gereksinimlerini tanımlar:

- **Çok katmanlı tespit:** Tek katmana bağımlı mimariler, o katman etkisizleştğinde bütünüyle kör kalır.
- **Ölçüm sürekliliği:** Sinyal/gürültü oranı, marjinal katkı ve MTTD metrikleri (Bölüm 8.3) düzenli izlenir.
- **Kalibrasyon döngüsü:** Kontrollü simülasyon yılda en az iki kez; baseline yenileme çeyreklik.
- **Telemetri bağımlılığı yönetimi:** Sağlayıcı, saklama ve lisans bağımlılıkları envanterlenir; telemetri kaybı tespit kayıdır.
- **Aday özellik envanteri:** Hangi dedektörün hangi model varsayımına dayandığı kayıt altına alınır (Bölüm 4.4 tablosu); varsayım geçersizleştğinde dedektörün yeniden değerlendirilmesi gerekir.
- **Kapsam kayması izleme:** Bulut geçişi, uzaktan çalışma ve yeni hizmetler baseline'ı kaydırır; yenileme takvimi bu değişimlerle hizalanır.

11. Sonuç

Bu rapor, değerlendirilen akış düzeyi özellik ailesinde profil-uyumlu rejimlerde sınıflar arası ayrımın belirgin biçimde azalabileceğini göstermektedir: marjinal dağılım, güç spektral yoğunluğu, otokorelasyon, Hurst üsteli ve diyurnal profil. Bu, genel bir doygunluk teoremi değildir ve deneysel olarak kanıtlanmış evrensel bir sınır iddiası içermez; yüksek mertebeden bağımlılık, multifraktal spektrum, akışlar arası korelasyon ve uygulama/protokol tutarlılığı ayrım gücünü koruyabilir (Bölüm 5.4).

Kurumsal öneri üç maddede özetlenebilir:

1. Akış telemetrisi, ölçekleme ve kuyruk ölçümleriyle zenginleştirilmeli; pencere uzunluğu duyarlılık analiziyle gerekçelendirilmelidir.
2. Süreç ve oturum bağlamı, PID yeniden kullanımına karşı korunan bir anahtarla akış telemetrisine bağlanmalıdır.
3. Dedektörler, kurum kontrollü savunma profili simülatörü ile düzenli olarak kalibre edilmeli ve kanıt gücü sınıfı (tek başına / korelasyon gerektirir / korelasyon altyapısı) açıkça belgelenmelidir.

Tespit sorusu değişmiştir: "bu trafik düzenli mi" sorusu yerini "bu trafiği üreten süreç ve oturum bağlamı, iddia edilen kullanıcı ile tutarlı mı" sorusuna bırakmıştır.

Public-release kapsam notu: Bu çalışma belirli bir C2 implementasyonunun mimarisini veya operasyonel üretim ayrıntılarını açıklamaz. Tüm örnekler savunma, ölçüm ve detection-engineering kavramlarını göstermek amacıyla genelleştirilmiştir.

12. Ekler

Ek A — Matematiksel Türetmeler

A.1 Olay treni ve IAT dizisi. Periyodik olay dizisi $t_n = nT$ için:

$$x(t) = \sum_n \delta(t - nT) \Rightarrow X(f) = (1/T) \cdot \sum_k \delta(f - k/T) \\ IAT_n = T \Rightarrow DFT\{X_{IAT}\}[0] = NT, \quad DFT\{X_{IAT}\}[k] = 0 \quad (k \neq 0)$$

İki gösterim eşdeğer değildir; spektral çizgiler olay trenine aittir.

A.2 Model A (olay-zamanı jitter). $t_n = nT + \epsilon_n$, ϵ_n iid, $E[\epsilon] = 0$, $Var(\epsilon) = \sigma_\epsilon^2$:

$$IAT_n = T + \epsilon_n - \epsilon_{(n-1)} \\ Var(IAT_n) = 2\sigma_\epsilon^2 \\ Cov(IAT_n, IAT_{(n+1)}) = Cov(\epsilon_n - \epsilon_{(n-1)}, \epsilon_{(n+1)} - \epsilon_n) = -\sigma_\epsilon^2 \\ \rho_1 = -\sigma_\epsilon^2 / (2\sigma_\epsilon^2) = -0.5 \quad (\text{iid + sonlu varyans + fiziksel sıra korunumu altında})$$

$\epsilon \sim U(-pT, pT)$ için IAT simetrik üçgensel dağılımlıdır ve desteği $[T - 2pT, T + 2pT]$ aralığıdır. Üçgensellik bu dağılım tercihinin özgüdür; genel iid ve sonlu varyanslı ϵ için IAT dağılımının üçgensel olması gerekmez (genel durumda simetri ve $\rho_1 = -0.5$ korunur). $\rho_1 = -0.5$ sonucunun kapsamı üç koşula bağlıdır: (i) ϵ_n iid, (ii) $Var(\epsilon) < \infty$, (iii) indekslenen olay sırasının fiziksel zaman sırasını koruması. Olaylar zaman damgasına göre yeniden sıralanırsa, gözlenen IAT dizisi bu yapıyı korumayabilir. Garantili kronolojik sıra korunumu ve pozitif IAT desteği için $p < 0.5$ yeterli koşuldur (bkz. Bölüm 2.2); $p \geq 0.5$ durumunda kronolojik sıra garantisi ortadan kalkar. Spektral sonuç: PSD'de k/T noktalarında kütlesi $|\Phi_\epsilon(k/T)|^2$ ile orantılı atomlar ve yoğunluğu $(1 - |\Phi_\epsilon(f)|^2)$ ile orantılı sürekli bir bileşen bulunur; $\epsilon \rightarrow 0$ iken sürekli bileşen kaybolur, jitter genişliği arttıkça atomlar zayıflar. Atom kütleleri $2pk = m$, yani $k = m/(2p)$ koşulunda sıfırlanır ($m \in \mathbb{Z} \setminus \{0\}$); ancak bu koşulun bir çizgi atomunu gerçekten yok etmesi için k 'nın bir tamsayı harmonik indeksine denk gelmesi gerekir. Bu özellik yalnızca Model A'nın çizgi bileşenine aittir.

A.3 Model B (aralık jitter) ve yenilenme spektrumu. $IAT_n = T + U_n$, U_n iid, $E[U] = 0$. Üniormluk bu genel tanımdan doğrudan çıkmaz; yalnızca $U_n \sim \text{Uniform}(-pT, pT)$ seçiminde $IAT_n \sim \text{Uniform}(T - pT, T + pT)$ ve bağımsızlık geçerlidir. Yenilenme sürecinin tanımı için aralıkların neredeyse kesin pozitif olması gerekir: $P(T + U_n > 0) = 1$; üniform örnekte bu, $T - pT > 0$, yani $p < 1$ koşuluna karşılık gelir. (Bu koşul, Model A'daki $p < 0.5$ sıra korunumu koşulundan farklıdır.)

$$\begin{aligned} t_n &= \sum_{i \leq n} \text{IAT}_i && (\text{kümülatif; yenilenme süreci}) \\ \lambda &= 1/T && (\text{hız}) \\ \psi(f) &= E[e^{(-j2\pi f \cdot \text{IAT})}] && (\text{aralık dağılımının karakteristik fonksiyonu}) \end{aligned}$$

Sürekli (lattice olmayan) aralık dağılımına sahip bir yenilenme sürecinde $f \neq 0$ için spektrum **mutlak süreklidir; çizgi bileşeni yoktur**. Sürekli spektral yoğunluk, yenilenme PSD ifadesiyle verilir:

$$S(f) = \lambda \cdot (1 - |\psi(f)|^2) / |1 - \psi(f)|^2 \quad (f \neq 0)$$

$f = 0$ noktasındaki atom, sürecin ortalamasından kaynaklanır ve bu ifadenin kapsamında değildir. Poisson kontrolü: $\psi(f) = \lambda / (\lambda + j2\pi f)$ için $S(f) = \lambda$, yani düz (beyaz) spektrum elde edilir. Aralık dağılımı T noktasına dejenere oldukça $|\psi(f)| \rightarrow 1$ olur ve sürekli spektrum k/T noktalarındaki çizgilere daralır; periyodik çizgi spektrumu bu **dejenere limitin** sonucudur, sürekli dağılımın kendisinin özelliği değildir.

A.4 Model ayrımı. İki model aynı jitter dağılımını (örneğin üniform) kullansa bile spektral yapıları farklıdır:

	Çizgi bileşeni (' k/T ')	Sürekli bileşen	IAT bağımlılığı
Model A (olay-zamanı)	Var; kütle $ \Phi_\epsilon(k/T) ^2$ ile orantılı	Var; yoğunluk $(1 - \Phi_\epsilon(f) ^2)$ ile orantılı	$\rho_1 = -0.5$
Model B (aralık)	Yok ($f \neq 0$ için)	Var; $S(f) = \lambda(1 - \psi(f) ^2) / 1 - \psi(f) ^2$	Yok (bağımsız)

Bu nedenle "iki modelin ortak spektral sıfırları" gibi bir ifade geçersizdir: Model B'de sıfırlanacak çizgi bileşeni yoktur; Model A'da gözlenen $k = m/(2p)$ ($m \in \mathbb{Z} \setminus \{0\}$) sıfırlanması yalnızca çizgi atomlarına aittir ve bir atomu gerçekten yok etmesi için k 'nın tamsayı harmonik indeksine denk gelmesi gerekir. Bir modelin IAT dağılımını diğerinin spektral sonucuyla birleştirmek de aynı nedenle geçersizdir.

A.5 Üstel jitter. $X = T + Y$, $Y \sim \text{Exp}(\lambda)$, $E[Y] = 1/\lambda$:

$$\begin{aligned} P(Y > y + t \mid Y > y) &= e^{(-\lambda t)} && (\text{asıl memoryless özellik}) \\ P(X > s + t \mid X > s) &= e^{(-\lambda t)}, \quad s \geq T && (\text{eşdeğer ifade}) \\ P(X > s + t \mid X > s) &\neq P(X > t) && (X \text{ kaydırılmıştır}) \end{aligned}$$

A.6 Ölçekleme ve ağır kuyruk.

$$\begin{aligned} \text{Var}(X^{(m)}) &= \sigma^2 \cdot m^{(2H-2)} && (\text{durağan artışlı, sonlu varyanslı limit}) \\ \text{SRD: } \sum_k |p(k)| &< \infty && \text{LRD: } \sum_k |p(k)| = \infty, \quad p(k) \sim c \cdot k^{(2H-2)} \\ \text{ON/OFF Pareto kaynaklar: } H &= (3 - \alpha)/2, \quad 1 < \alpha < 2 \\ \alpha \leq 1 &\Rightarrow \text{beklenen değer ıraksar; } 1 < \alpha < 2 \Rightarrow \text{varyans ıraksar} \end{aligned}$$

A.7 Hill kestiricisi. Sıralı istatistikler $x_{(1)} \geq x_{(2)} \geq \dots \geq x_{(n)}$ için:

$$\hat{\alpha}_{\text{Hill}}(k) = \left[(1/k) \cdot \sum_{i=1}^k \ln(x_{(i)} / x_{(k+1)}) \right]^{-1}$$

Kestirici, dağılımın düzenli değişen (regularly varying) kuyruk varsayımı altında tutarlıdır ve sonucu eşik/ k seçimine duyarlıdır. Bu nedenle Hill çizimi kararlılık tanınması ile birlikte raporlanmalı; log-log CCDF eğrisi ise tanısal araç olarak kullanılmalıdır (bkz. Bölüm 3.2). Kırılmış kuyrukta $\hat{\alpha}_{\text{Hill}}(k)$, kesilme sınırına yaklaştıkça artar; log-log CCDF eğrisi düzleşir ve ani düşer.

Ek B — Sözlük

Terim	Açıklama
IAT	İki ardışık paket/oturum arasındaki süre
Olay treni	Zaman ekseninde nokta süreci olarak modellenen olay dizisi
SRD / LRD	Kısa menzilli / uzun menzilli bağımlılık (toplanabilir / toplanamaz otokorelasyon)
MMPP	Markov-Modüli Poisson Süreci; üstel faz süreleri, tipik olarak $H \approx 0.5$
Yarı-Markov süreç	Faz süreleri üstel olmayan Markov-modüli süreç
ON/OFF modeli	Kaynakların açık/kapalı dönemlerle modellenmesi; ağır kuyrukla LRD üretir

Terim	Açıklama
Yenilenme süreci	Bağımsız ve özdeş dağılımlı aralıklarla tanımlı nokta süreci
Palm-Khintchine	Bağımsız yenilenme süreçlerinin süperpozisyonunun, belirli asimptotik koşullarda Poisson'a yakınsaması
fBm / fGn	Fraksiyonel Brown hareketi (süreç durağan değildir; artışları durağandır) / fraksiyonel Gauss gürültüsü (durağan artış süreci)
Hurst üsteli (H)	Öz-benzerlik ölçüsü; $H > 0.5$ LRD rejimini gösterir
Ağır kuyruk indeksi (α)	Kuyruk kalınlığı; $1 < \alpha < 2$ aralığında ırsıkayan, ON/OFF faz süresi değişkeninin varyansdır (limit sürecin varyansı değil)
sinc	Bu raporda $\sin(x)/x$ (normalize edilmemiş)
CCDF	Tamamlayıcı kümülatif dağılım fonksiyonu
Kuantizasyon / tarak	Zamanlayıcı granülaritesinin IAT dağılımında bıraktığı yığılma (aday özellik)
Aday özellik	Tek başına kanıt oluşturmayan, korelasyonla değerlendirilen ölçüm
Korelasyon altyapısı	Kendisi tehdit kanıtı üretmeyen; diğer ölçümlerin kanıt değerini yükselten telemetri/eşleme katmanı (örneğin T6, T12)
Yenilenme PSD ifadesi	Sürekli aralık dağılımlı yenilenme süreci için $S(f) = \lambda(1 - \psi(f) ^2)/ 1 - \psi(f) ^2$; $f \neq 0$ için sürekli spektrum
Değişmez özellik	Matematiksel olarak zorunlu sonuç (örneğin Model A'da $\rho_1 = -0.5$)
ETW / eBPF	Windows olay izleme altyapısı / Linux çekirdek içi programlanabilir gözlem katmanı

Ek C — MITRE ATT&CK Eşlemesi ve Kapsam Notu

ATT&CK, saldırgan davranışını sınıflandıran bir taksonomidir; savunma ölçümlerini değil, gözlemlenen teknikleri tanımlar. Aşağıdaki eşlemeler **bağlama duyarlı** olarak okunmalıdır: gözlemlenen davranış ilgili teknikle uyumlu olabilir; bu, tek başına teknik ataması anlamına gelmez. Savunma analitiğine teknik atanmaz.

Taktik	Uyumlu Olabileceği Teknik	Eşleme Notu
T1, T5, T14	T1071, T1029	Zamanlama ve pencere ölçümleri; protokol/pencere seçimi tek başına ayırt edici değildir
T2, T11	T1030	Boyut sınırlama davranışı ile uyumlu olabilir; protokol sınırları karıştırıcıdır
T3	T1497.003	Zamanlayıcı güdümlü desen, zaman temelli kaçınma ile uyumlu olabilir; karıştırıcı sayısı yüksektir
T4	N/A	Filogeni/benzerlik ölçümü bir savunma ölçümüdür; ATT&CK karşılığı yoktur
T6, T12	N/A (korelasyon mimarisi)	Gözlemlenen teknik farklı olabilir; analitik yeteneğe teknik atanmaz
T7	T1053.005, T1543.003	Servis/görev bağlamı bu tekniklerle uyumlu olabilir
T8	N/A	Girdi/ağ korelasyonu bir olasılıksal ölçümdür
T9	T1497.003	Uyku deseni zaman temelli kaçınma ile uyumlu olabilir
T10	T1071.001, T1573.002	Web protokolleri ve şifreli kanal kullanımı
T13, T15	N/A	Aldatma ve doğrulama savunma tarafı etkinlikleridir
T16	T1071, T1001.002	Depolama alt sistemi doğrudan geçiş denetimi

Taktik	Uyumlu Olabileceği Teknik	Eşleme Notu
T17	T1001	IOMMU ve DMA tutarlı tampon doğrulaması
T18	T1497	PMU donanımsal bellek bariyeri frekansı
T19	T1027, T1071	İnsan varlığı nedenselliği ve boşta korelasyonu
T20	T1573.002, T1071.001	Alt sistem TLS yığını ve ETW WinHTTP sapması

Ek D — Kaynakça

- Leland, W., Taqqu, M., Willinger, W., Wilson, D. (1994). *On the Self-Similar Nature of Ethernet Traffic*. IEEE/ACM Transactions on Networking.
- Paxson, V., Floyd, S. (1995). *Wide-Area Traffic: The Failure of Poisson Modeling*. IEEE/ACM Transactions on Networking.
- Willinger, W., Taqqu, M., Sherman, R., Wilson, D. (1997). *Self-Similarity Through High-Variability: Statistical Analysis of Ethernet LAN Traffic at the Source Level*. IEEE/ACM Transactions on Networking.
- Crovella, M., Bestavros, A. (1997). *Self-Similarity in World Wide Web Traffic: Evidence and Possible Causes*. IEEE/ACM Transactions on Networking.
- Fischer, W., Meier-Hellstern, K. (1993). *The Markov-Modulated Poisson Process (MMPP) Cookbook*. Performance Evaluation.
- Andersen, A., Nielsen, B. (1998). *A Markovian Approach for Modeling Packet Traffic with Long-Range Dependence*. IEEE Journal on Selected Areas in Communications.
- Norros, I. (1995). *On the Use of Fractional Brownian Motion in the Theory of Connectionless Networks*. IEEE JSAC.
- Taqqu, M., Teverovsky, V., Willinger, W. (1995). *Estimators for Long-Range Dependence: An Empirical Study*. Fractals.
- Hill, B. (1975). *A Simple General Approach to Inference About the Tail of a Distribution*. Annals of Statistics.
- Palm, C. (1943). *Intensitätsschwankungen im Fernspreverkehr*. Ericsson Technics.
- Khinchin, A. (1955). *Mathematical Methods in the Theory of Queueing*. Griffin.
- Daley, D., Vere-Jones, D. (2003). *An Introduction to the Theory of Point Processes*. Springer.

Multifraktal trafik analizi

- Feldmann, A., Gilbert, A., Willinger, W. (1998). *Data Networks as Cascades: Investigating the Multifractal Nature of Internet WAN Traffic*. ACM SIGCOMM.
- Abry, P., Veitch, D. (1998). *Wavelet Analysis of Long-Range-Dependent Traffic*. IEEE Transactions on Information Theory.
- Riedi, R., Crouse, M., Ribeiro, V., Baraniuk, R. (1999). *A Multifractal Wavelet Model with Application to Network Traffic*. IEEE Transactions on Information Theory.
- Veitch, D., Abry, P. (1999). *A Wavelet-Based Joint Estimator of the Parameters of Long-Range Dependence*. IEEE Transactions on Information Theory.
- Kantelhardt, J., Zschiegner, S., Koscielny-Bunde, E., Havlin, S., Bunde, A., Stanley, H. (2002). *Multifractal Detrended Fluctuation Analysis of Nonstationary Time Series*. Physica A.

Uzun hafıza altında durağanlık ve yapısal kırılma testleri

- Granger, C., Joyeux, R. (1980). *An Introduction to Long-Memory Time Series Models and Fractional Differencing*. Journal of Time Series Analysis.
 - Hosking, J. (1981). *Fractional Differencing*. Biometrika.
 - Baillie, R. (1996). *Long Memory Processes and Fractional Integration in Econometrics*. Journal of Econometrics.
 - Krämer, W., Sibbertsen, P., Kleiber, C. (2002). *Long-Memory versus Structural Breaks: An Overview*. Statistical Papers.
 - Künsch, H. (1989). *The Jackknife and the Bootstrap for General Stationary Observations*. Annals of Statistics.
- (Standart blok bootstrap; kısa hafıza/zayıf bağımlılık çerçevesi — LRD altında geçerlilik ayrıca doğrulanmalıdır)

- Politis, D., Romano, J. (1994). *The Stationary Bootstrap*. Journal of the American Statistical Association. (Standart stationary bootstrap; aynı sınırlama geçerlidir)

Makine öğrenmesi tabanlı ağ anomali tespiti

- An, J., Cho, S. (2015). *Variational Autoencoder Based Anomaly Detection Using Reconstruction Probability*. SNU Data Mining Center Technical Report.
- Mirsky, Y., Doitshman, T., Elovici, Y., Shabtai, A. (2018). *Kitsune: An Ensemble of Autoencoders for Online Network Intrusion Detection*. Network and Distributed System Security Symposium (NDSS).
- Boutaba, R., Salahuddin, M., Limam, N., Ayoubi, S., Shahriar, N., Estrada-Solano, F., Caicedo, O. (2018). *A Comprehensive Survey on Machine Learning for Networking: Evolution, Applications and Research Opportunities*. Journal of Internet Services and Applications.
- Lopez-Martin, M., Carro, B., Sanchez-Esguevillas, A., Lloret, J. (2017). *Network Traffic Classifier With Convolutional and Recurrent Neural Networks for Internet of Things*. IEEE Access. (CNN/RNN tabanlı trafik sınıflandırma; IAT histogramı veya spektral özellik iddiası içermez)
- Chalapathy, R., Chawla, S. (2019). *Deep Learning for Anomaly Detection: A Survey*. arXiv:1901.03407.

Platform ve telemetri dokümantasyonu

- MITRE Corporation. *ATT&CK Enterprise Matrix*.
- Microsoft. *Event Tracing for Windows: sağlayıcı ve olay şeması dokümantasyonu*.
- Linux Kernel Documentation. *BPF CO-RE ve tracepoint/kprobe programlama referansı*.

Ek E — Yasal Bildirim ve Fikri Mülkiyet Zırhı

E.1 Telif Hakkı ve Mülkiyet Bildirimi

İşbu teknik rapor, mimari analizler, matematiksel modeller, tespit kuralları, kaynak kodları ve türetilmiş tüm ampirik veriler © 2026 Oğulcan (ByGhost) Erarslan adına tescilli olup tüm hakları saklıdır. Dokümanın içeriği 5846 sayılı Fikir ve Sanat Eserleri Kanunu, Bern Sözleşmesi ve ilgili uluslararası telif hukuku mevzuatıyla tam koruma altındadır.

E.2 Lisans Kapsamı ve Kısıtlamaları (CC BY-NC-ND 4.0)

Bu çalışma, Creative Commons Attribution-NonCommercial-NoDerivatives 4.0 International (CC BY-NC-ND 4.0) lisansı şartlarına tabidir:

- **Atıf (Attribution):** Dokümandan alıntı yapılması durumunda yazarın adı (Oğulcan 'ByGhost' Erarslan), doküman başlığı, DOI/versiyon numarası ve resmi kaynak linki (<https://byghost.tr/> ve <https://github.com/ByGh00st>) açıkça ve değiştirilmeksizin belirtilmelidir.
- **Gayriticari (Non-Commercial):** Bu rapor, içerisindeki taktiksel modeller, tespit heuristikleri ve mimari tasarımlar doğrudan veya dolaylı hiçbir ticari amaçla kullanılamaz.
- **Türetilemez (No-Derivatives):** Rapor içeriği değiştirilemez, parçalanamaz, yeniden düzenlenemez veya üzerine inşa edilerek yeni bir türev çalışma olarak yayımlanamaz.

E.3 Ticari Entegrasyon ve Ürünleştirme Yasağı (Commercial Prohibition)

Yazarın ıslak imzalı veya doğrulanabilir kriptografik imzalı resmi yazılı izni ve ticari lisans sözleşmesi olmaksızın:

1. İşbu dokümandaki tespit taktikleri (T1–T20), çapraz katman telemetri korelasyon algoritmaları, eBPF ve Sigma kural mantıkları ticari bir siber güvenlik ürününe (EDR, NDR, SIEM, SOAR, XDR), bulut güvenlik platformuna veya ücretli tehdit istihbaratı/SOC izleme servisine doğrudan ya da dolaylı olarak entegre edilemez.
2. 'Kaynak göstermek' veya 'atıfta bulunmak', ticari ürünleştirme ve servis entegrasyonu yasağını ortadan kaldırmaz.
3. Dokümanın iç sayfalarının veya tablolarının 'white-label' veya farklı bir kurumsal kimlik altında ticari bülten veya danışmanlık çıktısı olarak sunulması fikri mülkiyet hırsızlığı teşkil eder.

E.4 Yargı Yetkisi ve İhlal Tazminatı

İşbu lisans şartlarının ihlali durumunda İstanbul (Çağlayan) Fikri ve Sınai Haklar Hukuk Mahkemeleri ve İcra Daireleri münhasır yargı yetkisine sahiptir. Telif hakkı sahibi, haksız ticari kazançların iadesi, maddi ve manevi tazminat ile ceza davası açma hakkını saklı tutar.

BYGHOST SECURITY

Oğulcan (ByGhost) Erarslan

Senior Solutions Architect | Cyber Security Specialist

ByGhost Security · <https://byghost.tr/> · github.com/ByGh00st · linkedin.com/in/byghost-tr